

GJØVIK UNIVERSITY COLLEGE

BACHELOR THESIS

Snowman

A complete, effective and secure rule management system for Snort

Authors:
Thomas NYHEIM
Eirik SKOGSTAD
Eigil OBRESTAD

Supervisor:
Slobodan PETROVIC



May 17, 2014

Participants
Thomas NYHEIM
Eirik SKOGSTAD
Eigil OBRESTAD

Supervisor
Slobodan PETROVIC

Employer
Norwegian Armed Forces, Cyber ett eller annet, AVDELING BKI

Employer Contact
Capt. Jarle KITTILSEN, epost, tlf

Keywords
Software Development, Intrusion Detection System, Software Performance Testing, Snort

100 Pages - **4** Appendices

AVDELING FOR
INFORMATIKK OG MEDIETEKNIKK
HØGSKOLEN I GJØVIK
POSTBOKS 191
2802 GJØVIK

DEPARTMENT OF COMPUTER SCIENCE
AND MEDIA TECHNOLOGY
GJØVIK UNIVERSITY COLLEGE
BOX 191
N-2802 GJØVIK
NORWAY

English Abstract

««««< .mine

Trenger kort intro om trusler mot datanettverk. In order to properly protect a computer network it is vital to be able to detect these threats, which is done by using an intrusion detection system (IDS). IDS's will normally operate by analysing the network traffic which is compared to threat-patterns defined in signatures, raising alerts when threats are detected. Given the number of possible threats to a computer network, IDS's often have a huge amount of signatures that must be properly managed in order to maintain both a secure and usable network. Signature management therefore involves enabling and disabling of signatures, as well as keeping them all up to date. This can be a challenging task even for small-sized organisations, as the IDS might operate on multiple parts of the network simultaneously. This thesis presents a software which facilitates signature management in environments with multiple instances of the IDS, called sensors, by using a central server which automatically updates and distributes signatures to the sensors. Furthermore, the software introduces a novel way of automatic management of signatures on each sensor. The software is controlled with a simple and intuitive graphical user interface which supports multiple users. This thesis also compares the functionality and efficiency of the software with similar signature management systems through a theoretical analysis of performance complemented with practical tests.

======= Snort is a leading open source intrusion detection system that is used to protect computer networks the world over; by law enforcement, the military and security specialists alike. The system has many good projects going for it when it comes to handeling the actual events and alerts the system generates, but it is lacking a good way of dealing with the signatures (also known as rules) it uses to detect malicious network traffic.

This project continues the work that resulted in the prototype Bring Home The Bacon in 2012 and takes it a step further into something that can be used in a professional production environment. We have developed a rule management system for Snort which we have called Snowman, that can scale to the needs of a larger, more distributed deployment of intrusion detection systems. Snowman also employs principles such as least privilege, encrypted communication and form validation to ensure that an application used to secure networks, does not become a weakness in and of itself.

Because of the performance demands involved, the project also conducted a performance test that compares Snowman with two other similar programs in order to verify if we had met our performance goals. While we did not meet those goals, we did find a performance bottleneck in one of our systems modules that we managed to fix and increase our performance tenfold. Our performance testing has become a lesson in how important performance testing can be during development to weed out bottlenecks from a system before it is released.

»»»»> .r376

Norwegian Abstract

Kort versjon av rapporten.

Preface

Acknowledgements

We would like to thank our mentor from Gjøvik University College, prof. Slobodan Petrovic, for his help and input during the project. We would also like to thank Avdeling BKI for assignig us this project and the help with forming requirements and the software testing, and especially Jarle Kittilsen who took on a role as a supplementary mentor.

We would also like to acknowledge Gjøvik University College, that has been an arena for expanding our knowledge in the past few years and the knowledge we've accrued are the foundation of which this project is laid upon.

Legal

SNORT® is a registered trademark of Sourcefire, Inc., henceforth referred to as Snort.

Logo artwork commissioned by Kerrigan, `http://rattlesire.deviantart.com/`.

Glossary

This chapter contains an alphabetical list of technical terms used throughout the report along with their definition.

CLI Command-line interface.

Daemon A computer program that runs as a background process, usually without any user interaction.

DOM Document object model.

HDD Hard disk drive.

HTML Hypertext markup language.

HTTP Hypertext transfer protocol.

I/O Input / Output, used to describe data flow to and from devices such as hard drives.

IDS Intrusion detection system.

MD5 A cryptographic hash function producing a 128-bit hash value.

MVC Model-view-controller.

Open Source Software Software where the source code is publicly available and is licensed in such a way that the copyright holder grants the rights to study, alter and redistribute the software to anyone for any purpose [1].

ORM Object-relational mapping.

RAM Random access memory.

RPC Remote procedure call.

RPM Rounds per minute.

SCP Secure Copy - a file transfer protocol.

Sensor A computer system wherein Snort and/or other security software is recording network traffic and produces alerts when malicious content is detected.

SSD Solid state drive.

SSL Secure sockets layer.

URL Uniform resource locator.

XML Extensible markup language.

Contents

English Abstract . . . ii
Norwegian Abstract . . . iii
Preface . . . iv
Glossary . . . v
Contents . . . vi
List of Figures . . . x
List of Tables . . . xi
1 INTRODUCTION . . . **1**
1.1 Project Background . . . 1
1.2 Previous Work . . . 1
1.3 Project Description . . . 2
1.4 Target Audence . . . 2
1.5 Project Objectives . . . 2
1.5.1 Result Objectives . . . 2
1.5.2 Effect Objectives . . . 3
1.6 Academic Background . . . 4
1.7 Framework . . . 4
1.7.1 Software Development Methodology . . . 4
1.7.2 Schedule . . . 5
1.7.3 Project Organization . . . 5
1.8 Document Structure . . . 6
1.8.1 Special Styles Used . . . 6
2 EXISTING SOLUTIONS . . . **7**
2.1 Bring Home The Bacon . . . 7
2.2 Snortmanager . . . 8
2.3 Other notable programs . . . 8
2.4 Research on Software Performance . . . 8
2.5 Functionality comparison . . . 9
3 REQUIREMENTS SPECIFICATION . . . **12**
3.1 Functional Requirements . . . 12
3.1.1 Program Workflow . . . 12
3.1.2 Use Case Diagram . . . 14
3.1.3 Domain Model . . . 14
3.2 Supplemental Requirements . . . 15
3.2.1 Functionality . . . 15
3.2.2 Usability . . . 15
3.2.3 Reliability . . . 15
3.2.4 Performance . . . 16
3.2.5 Security . . . 16
3.2.6 Interoperability . . . 16

3.2.7 Licensing . . . 16
3.3 Constraints . . . 16
3.3.1 Platform . . . 16
3.3.2 Data security . . . 16
3.3.3 Graphical User Interface . . . 17
3.4 Security Assessment . . . 17
4 BASICS OF IDS AND SNORT . . . 19
4.1 Rules . . . 19
4.2 Rulesets . . . 19
4.3 Generators . . . 19
4.4 References . . . 20
4.5 Event and detection filters . . . 20
4.6 Rule suppression . . . 20
5 DESIGN . . . 21
5.1 General Design . . . 21
5.1.1 Centralized or Distributed Setup? . . . 21
5.2 Server Design . . . 22
5.2.1 Architecture . . . 22
5.2.2 User Interface . . . 23
5.2.3 Database . . . 24
5.3 Client . . . 25
5.3.1 Architecture . . . 25
5.3.2 Database . . . 25
6 IMPLEMENTATION . . . 29
6.1 Programming Languages . . . 29
6.1.1 Standards and Guidelines . . . 30
6.2 Development environments . . . 31
6.2.1 Environments . . . 31
6.2.2 Version control . . . 31
6.3 Frameworks . . . 31
6.3.1 Django . . . 31
6.3.2 SQLAlchemy . . . 31
6.3.3 jQuery . . . 32
6.3.4 Bootstrap . . . 32
6.4 Core module . . . 32
6.4.1 Rules and rule revisions . . . 33
6.4.2 Rulesets . . . 33
6.4.3 Sensors . . . 33
6.4.4 Comments . . . 33
6.5 Update module . . . 34
6.5.1 Sources . . . 34
6.5.2 Files . . . 34
6.5.3 Running an update . . . 35
6.5.4 Rule parsing . . . 36
6.5.5 Classification, Generator and Reference Type parsing . . . 36
6.5.6 Saving . . . 37

6.6 Tuning module . . . 38
6.7 Distribute . . . 38
6.7.1 Initiating the Distribution . . . 38
6.7.2 Synchronization . . . 39
6.7.3 Generating Snort Configuration . . . 39
6.8 Graphical User Interface . . . 39
6.8.1 Structure . . . 40
6.8.2 Design . . . 40
6.8.3 Overview of central GUI features . . . 40
6.9 Logging . . . 45
6.10 Configuration Files . . . 45
6.10.1 Server Configuration File . . . 45
6.10.2 Client Configuration File . . . 46
6.11 Documentation . . . 47
6.12 Deployment . . . 47
6.12.1 Snowman Server . . . 47
6.12.2 Snowman Client . . . 49
7 SOFTWARE TESTING . . . 50
7.1 Strategy . . . 50
7.2 Description of Problems . . . 50
7.2.1 Rule insertion . . . 50
7.2.2 List Pagination . . . 51
7.2.3 The Ever Changing Number of Changes . . . 51
8 PERFORMANCE ANALYSIS . . . 52
8.1 Theoretical Analysis . . . 52
8.1.1 Effectiveness of Update Processing . . . 52
8.1.2 Effectiveness of Rule Distribution . . . 52
8.1.3 GUI Latency . . . 53
8.1.4 Linearity in Performance . . . 53
8.2 Practical analysis . . . 53
8.2.1 Definitions . . . 53
8.2.2 Environment . . . 53
8.2.3 Test suites . . . 53
8.2.4 Update processing tests . . . 54
8.2.5 Rule distribution tests . . . 56
8.2.6 Interface loading tests . . . 56
8.2.7 Abandoned tests . . . 56
9 RESULTS OF PERFORMANCE TESTING . . . 58
10 ANALYSIS OF PERFORMANCE TESTING RESULTS . . . 61
10.1 Effectiveness of update processing . . . 61
10.2 Effectiveness of rule distribution . . . 62
10.3 GUI latency . . . 62
10.4 Linearity in performance . . . 63
10.5 Conclusions . . . 63
11 CONCLUSIONS . . . 64
11.1 Results . . . 64

11.2 Future Development 64
11.3 Group Evaluation 65
11.3.1 Introduction 65
11.3.2 Organization 65
11.3.3 Work distribution 66
11.3.4 What could have been done differently 66
11.3.5 Subjective views 66
11.4 Conclusion 66
Bibliography **67**
Appendices **69**
A PROJECT PLAN **70**
B MEETING RECORDS **71**
B.1 Project Decision Meeting Presentation 71
B.2 Meeting Minutes 71
B.3 Sprint Planning Meetings 71
C WORKLOG **72**

List of Figures

1 Agile development model [2] 4
2 Program Workflow 12
3 Program Modules 13
4 Use Case Diagram 14
5 Conceptual Class Diagram 15
6 General architecture 21
7 Server Architecture 23
8 Core server-database 25
9 Tuning server-database 26
10 Update server-database 27
11 Client Architecture 27
12 Client Database 28
13 Applying a filter to a rule on a sensor 38
14 GUI Structure 40
15 Rules page 41
16 Rulesets page 42
17 Update progressbar 42
18 Update changes 43
19 Form validation 44

List of Tables

1 Functionality comparison chart. 11
2 Security Assessment 18
3 Effects of different filter types. 20
4 Rule options used in this system. 35
5 Test systems. 54
6 Test cases in update processing. 55
7 Test results for interface performance. 58
8 Test results for update processing. 59
9 Test results for sensor synchronization. 60
10 Average processing time per rule. 61
11 Comparison of processing time for many files vs one file. 62
12 Empirical linear correlation coefficients for update processing. 63
13 Worklog 72

1 INTRODUCTION

1.1 Project Background

The Norwegian Armed Forces Cyber Defense (CYFOR) unit for Computer Network Defense (CND), Department of Critical Infrastructure Protection (Avdeling BKI in Norwegian), is responsible for detecting and stopping cyber-attacks against the critical infrastructure and command and control systems utilized by the Norwegian military. One of the tools used to carry out this task is the open source IDS Snort [3].

Snort is a leading [4] open source IDS that is used to detect potentially unwanted or malicious network traffic based on predefined patterns described in signatures. There are both free and commercial signatures available for Snort and as Snort has been highly adopted by the security community, these signatures are continually updated and maintained. For large networks, an IDS will often operate in multiple parts of the network simultaneously, where each separate instance of the IDS is known as a *sensor*.

The management of Snort signatures (henceforth referred to as rules) is cumbersome in multi-sensor environments without a centralized service which can assure that all sensors are synchronized with the latest rules. Avdeling BKI has therefore challenged a group of students from Gjøvik University College (GUC) to design and develop a more functional, effective and secure rule management system for Snort that can continue to live on beyond this project.

1.2 Previous Work

Studies [5] have shown that a good rule management system for Snort will improve the workflow and efficiency of the IDS significantly, and a prototype for such a system was built in 2012 called Bring Home The Bacon [5] (henceforth referred to as BHTB). This prototype has been in use at Avdeling BKI since 2012, but is suffering from lacks of functionality and efficiency due to being a proof-of-concept prototype. BHTB has, however, proven that there is a significant gain from having an intuitive Graphical User Interface (GUI) for managing rules. A GUI facilitates the work of the operator, as work is shifted from complex operations in a CLI to automatic execution of common routines triggered by buttons.

There was another similar project conducted at Gjøvik University College in 2012 called Snortmanager [6], which also deals with management of Snort rules. The Snortmanager project files are available as open source software [1], but no usage instructions are available. The source code has not been maintained since its initial release and is designed for a specific company in mind. Enabling, disabling and configuring rules is also cumbersome in this system as it is based on plaintext arguments in "policies" that users must construct themselves [6]. The rule distribution is also done manually from the files generated. All this makes Snortmanager unsuitable for Avdeling BKI and their routines.

Several add-ons and other Snort-related software exist [7], and a few of these are built to manage Snort rules, most notably Pulled_Pork [8] and Oinkmaster [9]. The key difference between all software mentioned in this section and Snowman is sheer functionality,

as further explained in Chapter 2.

1.3 Project Description

The purpose of this project is to design a system that provides a simple and efficient way of managing rules for the Snort IDS. The project is successor to BHTB and will expand on the good ideas from BHTB, and add functionality requested by Avdeling BKI to create a more adoptable open source rule management system for Snort. The project can be broken down into four main objectives:

1. Identify the challenges of rule management in an IDS such as Snort.
2. Describe how a good rule management system should operate.
3. Develop a good open source rule management system for Snort, at a high Technology Readiness Level [10].
4. Measure the performance of the system and compare this to other similar systems.

The first two objectives were addressed early on in the project during the initial design phase of the software. To develop a good rule management system, it is essential to consider the tasks in the two first objectives, as they form the basis of how the system in the third objective is designed. Challenges and best practices in rule management is therefore presented throughout this report to support the design decisions made in the final software solution.

As the project became very performance-oriented, the report also contains an initial study of software performance and practical performance test of related software.

1.4 Target Audence

Snowman is targeted at users of the Snort IDS in a larger production environment with many sensors and networks. More specifically, the target audience consists of security experts with a high degree of knowledge of Snort and computers in general.

This report is targeted at those which may be interested in discovering just how complex the rule structure of Snort is, and academics that are interested in reading about IDS software performance testing.

1.5 Project Objectives

1.5.1 Result Objectives

As stated in the project plan (Appendix A), this project has a goal of researching, designing and developing a system that as a minimum:

- Is more efficient than BHTB.
- Is developed as an engine that responds to API-calls.
- Is modular in design and allows future changes and additions that will not affect existing functionality.
- Is scalable enough to handle both small and large sets of IDS-sensors and rules in a production environment.

- Is able to download rules and rule sets from multiple customizable sources.
- Is able to distribute different rules to different IDS-sensors.
- Can download and distribute rules automatically at set intervals.
- Is capable of exporting rules for sharing.
- Has the capability to activate, deactivate, filter and suppress rules on a per sensor basis, in a user friendly way.
- Supports multi-user interaction.
- Can efficiently and safely work with different installations of Snort and various other third party tools, such as SNORBY [11].
- Is easy to install.
- Has an internal logging system.
- Is well-documented and can be easily adopted by anyone as open source software.

In addition, the project will attempt to add the following functionality:

- A graphical user interface.
- The mentioned user interface must be user friendly and intuitive, and require only limited knowledge of Snort rules from the user.
- The system can also distribute rules to Suricata [12], another Snort-like IDS, which can operate with the exact same rules as Snort.
- Implement security features that ensure confidentiality of rules.
- The project will investigate and potentially implement multi-threading technology or other optimization techniques to exploit modern hardware capacities.
- The system is capable of validating and checking rules for errors before they are distributed to sensors.
- The system supports commenting of the rules.
- The system supports writing custom rules and editing existing rules.

Once the system is developed, it will be released as an Open Source Software to the public in a well-documented format.

1.5.2 Effect Objectives

Forming baselines from the current prototype BHTB and from Snortmanager, the project has a goal to further increase the efficiency of rule management by investigating and implementing programming techniques such as multi-threading and caching to reduce latency and delays in the system by as much as 50%. The software must also maintain sublinearity in performance, i.e. 10 executions of the same job should take 10 times, or less, the amount of time as a single execution.

The achievement of these goals is to be measured by conducting several performance tests on the final software solution. Results will also be compared to the performance of BHTB and Snortmanager.

1.6 Academic Background

This project has benefited greatly from the fact that all three project members are all taking different computer science courses. Eirik is currently completing his undergraduate engineering degree in computer science at Gjøvik University College, and has practical experience in software development from a one-year technical work internship at CERN in Switzerland. Eigil is completing his undergraduate degree in network and system administration at Gjøvik University College, and has also spent one year at CERN working on network monitoring and administration. Thomas has been studying information security at Gjøvik University College, and has worked for Avdeling BKI for the past seven years prior to this project, working with threat detection and network traffic analysis, and thus has good knowledge of what Avdeling BKI needs and experience from the information security field in general. The variety of knowledge from each members background, the group has enjoyed a unique opportunity to draw from each other's strengths and approach the project from different perspectives.

1.7 Framework

1.7.1 Software Development Methodology

As this project has been very time restricted, the development needed to be as efficient as possible. The project group therefore had to find a model that utilized the available manpower in the best possible way. Considering the small size of the project group, large and complex development models would add too much bureaucracy to coordinate the project. A lightweight and efficient development model was preferred, so the group chose to utilize an agile [13] development model (Figure 1) structured into development cycles. This way, each group member could take an active part in the project and all members could feel a sense of ownership.

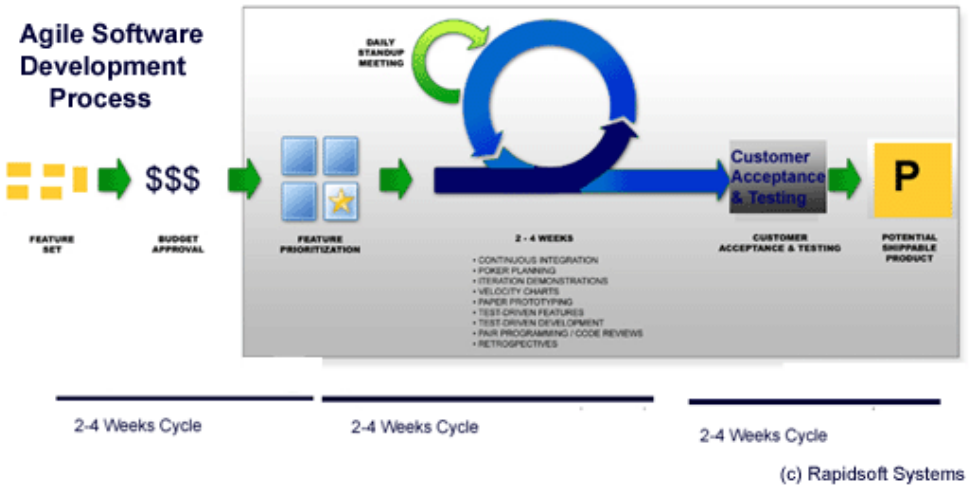


Figure 1: Agile development model [2]

By developing iterative and incrementally, the group combined the best of both the agile development world and from the very well-defined waterfall approach [14]. Feedback from Avdeling BKI and the project supervisor has been very important in the course of the project, in addition to having a structured and reasonable way of doing changes

to the plan while the project was running. At the same time the group was able to maintain the overall plan within cycles, so that it was possible to work individually, while still being well-coordinated.

To be able to develop all the modules of the project within the time frame, each development cycle consisted of multiple modules or functionality developed in parallel. This allowed for good utilization of time and personnel. The start of each cycle consisted of a meeting where the goals for the cycle were defined and individual tasks that we needed to get done were identified. This process bears similarity to the start of a sprint in the development model Scrum [15].

During the development part of the cycle, the group worked individually on the tasks that were defined in the planning phase. Regular meetings and cooperative programming within the group ensured that everyone pulled the project in the same direction. At the end of each cycle a working set of software was ready, which ideally complied with all the goals set at the start of each cycle. Meetings with Avdeling BKI were held between each cycle to present the progress, and to let them influence the direction of the project.

When all the development cycles were completed, final assurances were made that everything worked as intended and that all modules coexisted in harmony. This part of the development also consisted of some hands-on testing by Avdeling BKI and performance testing.

1.7.2 Schedule

This project had a comprehensive initial phase for mapping and designing of the system. The group spent the major part of the first two weeks planning how to implement the system. After the two weeks and before the start of the development, a “project decision meeting" was held with Avdeling BKI to receive feedback on the design and confirm that the system was modelled correctly for their needs.

After this, the implementation phase commenced, which consisted of development cycles as described above in Section 1.7.1. This phase was divided into five parts: four development cycles and a final cleanup/testing cycle. All the development cycles lasted two weeks, aside from the last development cycle and the cleanup/testing cycle, which lasted one week each. During these cycles the group conducted meetings with both the project mentor and Avdeling BKI every two weeks, timed so that these meetings took place on alternating weeks. This ensured continual feedback and advice throughout the development process.

After the development phase, focus was shifted from the software to the project report, and the group spent the final 5-6 weeks working on the report. The group benefitted from the work performed during the first weeks of the project which could go almost directly into the report.

1.7.3 Project Organization

Reflecting the fact that the project had multiple phases, the organisation of the project changed throughout the project. During the first few weeks the group spent most of the time together in a group room, cooperating in forming the design and discussing various solutions. Once most of the details had been worked out and the implementation phase began, there was more room and need to work individually to produce code. In this period, the group gathered together a few times a week to coordinate the progress and plan the next course of action. Throughout the project, most decisions have been made

either by speaking with Avdeling BKI or achieving consensus within the group.

1.8 Document Structure

INTRODUCTION - Contains an overview and description of the project and it's goals.

EXISTING SOLUTIONS - A rundown of other software and information relevant to the project.

REQUIREMENTS SPECIFICATION - Describes the requirements and scope of the software development.

CONCEPTS OF SNORT - This chapter will bring the reader up to speed on the concepts of Snort.

DESIGN - Details the architecture and design of the system.

IMPLEMENTATION - Describes how the system has been implemented.

SOFTWARE TESTING - A short description of how the system has been tested and some of the practical problems the project has encountered.

PERFORMANCE ANALYSIS - A chapter that describes what and how we have tested the system for performance.

RESULTS OF PERFORMANCE TESTING - The results of our performance testing is listed here.

ANALYSIS OF PERFORMANCE TESTING RESULTS - In this chapter we analyse and conclude our findings in the performance test.

CONCLUSIONS - The findings in this report is rounded up here.

BIBLIOGRAPHY

APPENDICES

1.8.1 Special Styles Used

Software names are written in a different font throughout the report, like so: Snowman. Source code is listed in an enclosed box with syntax highlighting (Listing 1.1). Source code can also appear in the text with the same syntax highlighting as the listings, especially note names of modules and classes which will appear as so: `module`, `Class`.

```
1 from module import Class
2
3 class Hello:
4   def printHello():
5     # Print a message
6     print 'Hello World!'
```

Listing 1.1: Source code example.

2 EXISTING SOLUTIONS

The following sections will quickly elaborate on the functionality of software similar to Snowman to identify the differences, weak and strong sides of the different solutions.

2.1 Bring Home The Bacon

Bring Home The Bacon was a by-product prototype of the Master thesis written by Henriksen in 2012 [5]. In the thesis, Henriksen seeks to prove that having a central, graphically-oriented system to administer multiple Snort-sensors and their rules, results in a signficant improvement in user workflow over the more traditional command-line environment. Henriksens tests show that such a system can double the users' work efficiency, if not more, as the command-line environment would scale very badly as the number of sensors increases. Henriksen also outlines a rule management process, which has been helpful during the initial phases of this project to map the program workflow (Section 3.1.1).

Despite being a prototype, BHTB offers the essential functionality required for managing rule sets on multiple sensors. It can display a list of rules which can also be turned on and off on different sensors, as well as a list of rule sets that can also be turned on and off, which will effect all rules in the rule set. This is considered a drawback, as BHTB does not offer a mechanism where rule sets can be disabled without affecting the state of the rules within. This means that the original state of the rules in a rule set is lost whenever the state of the rule set is changed. Snowman improves this by keeping the state of the rule sets separate from the state of the rules.

BHTB distributes rules to the sensors by generating all files centrally and sending them one by one via SCP. It determines which rules to distribute by comparing the main rule table with a second table representing which rules the sensor should not have. This way of distributing rules is considered ineffective, and has been solved differently in Snowman (section 5.1).

BHTB also supports manual creation of rule thresholds and suppressions, but does not offer any input validation, which makes the sensors vulnerable to crashes[1] in the case of invalid input. This weakness is taken into consideration in Snowman, which offers form validation.

BHTB is programmed with Python and uses the framework Tornado [16] as its Webserver, which works similar to Django, a framework used by Snowman, with its URL API system (Section 5.2.2). It also uses SQLite [17] as its database, which has limited abilities when it comes to relations and more complex data structures.

According to Avdeling BKI, BHTB really begins to show its limitations once the system is populated by a lot of rules[2] and sensors, which makes it clear that it has a scalability problem. Avdeling BKI has used BHTB in a production environment since 2012 and experiences the software as slow and cumbersome.

[1] Snort will simply not restart if something in the configuration files is malformed.
[2] In the five digit range.

2.2 Snortmanager

Snortmanager was created for a Bachelor thesis written at Gjøvik University College in 2012 [6], where the main purpose of the software was to make rule management more effective for the employing company. This was done by creating a central server with a rule-database which automatically downloads and updates rules from external sources. The user must then manually input which configurations are needed for a specified sensor and the system then creates configuration files for sensor. As Snortmanager has a high focus on producing configuration files containing the necessary rules and settings for each sensor, but does not automatically distribute the files to the sensors like Snowman does, the user is required to manually move the files to the sensor through some unrelated process.

2.3 Other notable programs

There are two other pieces of software that should also be mentioned. Pulled_Pork and Oinkmaster are both programs that can download rules and update Snort-sensors. These programs also contain some of the features found in Snowman and BHTB, and Pulled_Pork even supports Shared Object rules [18], which is not part of this project due to complexity. However, both of these programs suffer from the fact that they are command-line oriented. They are both very good at what they do, but lack the usability and efficiency offered by GUIs with buttons. These programs are a good choice for rule management in a small environment with one or very few sensors, but once the environment grows larger, with tens or even hundreds of sensors, they become ineffective.

2.4 Research on Software Performance

Since this project also investigates software performance, it is relevant to take a look at what others in the field have written on the subject. This subject is missing from most software development reports from Gjøvik University College, which can be explained by the usual high focus on agile development[13]. [19] mentions that agile programming is becoming mainstream and by its nature is a concern for the future of software performance engineering, as the primary focus of an agile project is on functionality.

A proper performance testing methodology was not immediately available for this project. However, the papers [20] and [21] gave a few pointers towards developing the test cases described in Chapter 8. Both articles also stress the importance of performance testing during the development rather than after it, as this allows for time to actually implement optimizations and improvements. The performance testing in this report does not strictly follow any of these methodologies, but it includes the most important elements of them, e.g. performance testing during development.

Early on in the project it became clear that Snowman is very I/O bound, as it performs a lot of database operations. The tests in this report show a noticable difference in performance between traditional rotational hard drives and SSDs. Myers comments on this in his Master thesis [22] which shows that SSD has a significant advantage over HDDs when it comes to random read performance but not when it comes to write performance. Note that these tests were performed in 2008, a time when SSD technology was fairly new and suffering from its different way of writing data[3]. As operating systems, drivers

[3] Features such as TRIM were introduced shortly after Myers thesis.

and disk controllers have improved, SSDs are now superior to HDDs in most tasks.

2.5 Functionality comparison

To easily visualize how various rule managers differ from each other, we have gathered key functionality from the most important pieces of such software and created a list of support for that functionality, which can be seen in table 1.

Feature	Snowman	BHTB	Snortmanager	Pulled_Pork	Oinkmaster
Rule download and storage	✓	✓	✓	✓	✓
Sensor administration	✓	✓	✓		
Graphical user interface	✓	✓	✓		
Automatic updates	✓	✓		✓	✓
Automatic synchronisation	✓	✓		✓	✓
Enable/disable rules	✓	✓			✓
Multiple sensors supported	✓	✓			✓
Can syncronise rules to sensors	✓	✓			✓
Displays change history of updates	✓	✓			✓
Can store meta-data about rules	✓	✓			
Can turn on or off whole rulesets	✓	✓			
Can turn on or off rulesets on individual sensors	✓	✓			
Can add filters and suppressions to rules	✓	✓			
Can add filters and suppressions to rules on a per sensor basis	✓	✓			
Has an internal logging system	✓	✓			
Can display list of rules in the system	✓	✓			
Can display meta-data in the system	✓	✓			
Normalized database	✓		✓	N/A	N/A
Does not require root to interact with Snort.	✓				
Turning rulesets on or off is non-propagating	✓		N/A	N/A	N/A
Can import filters and suppression from rule files	✓		✓	✓	✓
Has input validation	✓			N/A	N/A
Supports multiple database technologies	✓			N/A	N/A
Handles multiline rules	✓				✓
Can skip certain files	✓				✓
User can approve changes before sensors are updated	✓				✓
Is easy to install	✓				

Can import rules from arbitrary sources	✓				
Can organize rulesets in a hierarchy	✓				
Can create new custom rulesets	✓				
Can organize sensors in a hierarchy	✓				
Can syncronize rules to multiple sensors at a time	✓				
Has a user system	✓				
Supports autonomous sensors	✓				
Does not distribute everything every time	✓				
Supports SO rules				✓	✓
Can create new rules					
Number of objects in data structure	16	4	9	N/A	N/A

Table 1: Functionality comparison chart.

3 REQUIREMENTS SPECIFICATION

Many of the requirements for this system originates from functions that already exist in BHTB which need to be reproduced or improved. This means that the requirements for this project are closely tied to the way BHTB operates and its general workflow. This section outlines the specifications gathered from BHTB and from conversations with BKI.

3.1 Functional Requirements

3.1.1 Program Workflow

To aid the development of the functional requirements, the program workflow was charted in order to give a better understanding of what the system was expected to do. This was accomplished by going through the functionality of BHTB with the client and detailing the functions and various needs for improvement or additional functionality. From this, the workflow chart was drawn with the major parts of the system. In addition, Henriksen's management process [5] was taken into consideration.

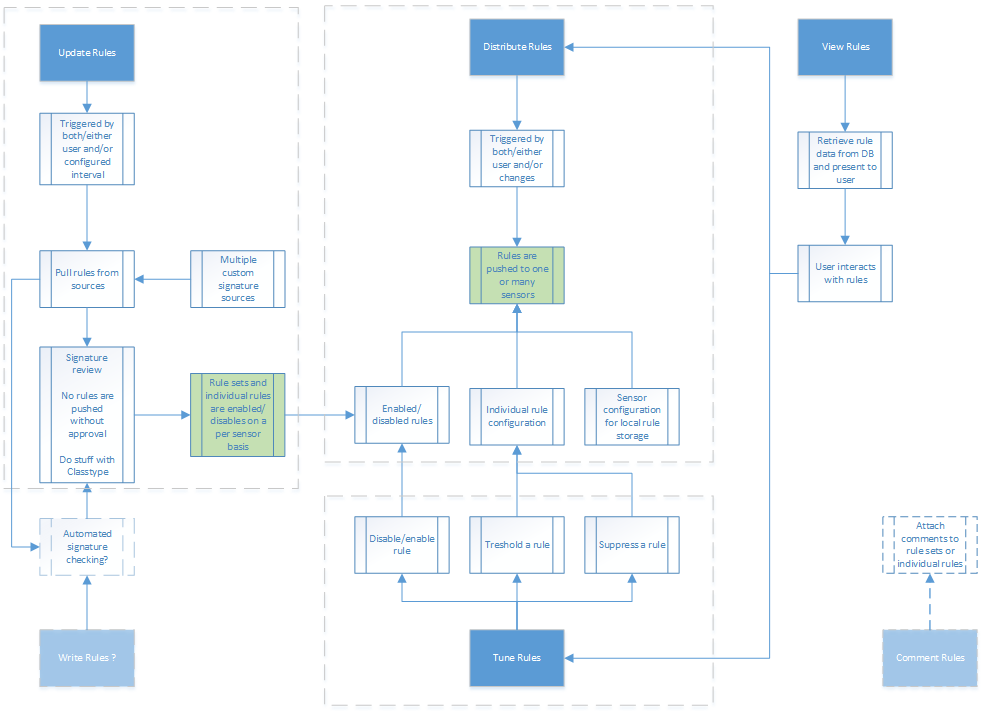


Figure 2: Program Workflow

To explain the workflow chart in Figure 2: the blue boxes are the major system functionalities, the green boxes are the major goals of the system and the arrows show the direction of flow the system should have. As can be seen, all of the program flow ends up with rules being syncronised to the sensors, making that a very central part of the system.

It is important to note that in the very early phase of development, we decided that writing rules, automatically check for errors and adding uder comments to them were nice-to-have (but still important) features that we could implement if we had time to do so. Hence they are greyed out in the drawings, and as the reader will notice further on in the report, these features were left for future work.

From this workflow we could outline a rough modular design (figure 3) based on the naturally separate functions of updating rules, tuning them, distributing them and showing them. We also added a database module, since most of our program was going to be centered around it.

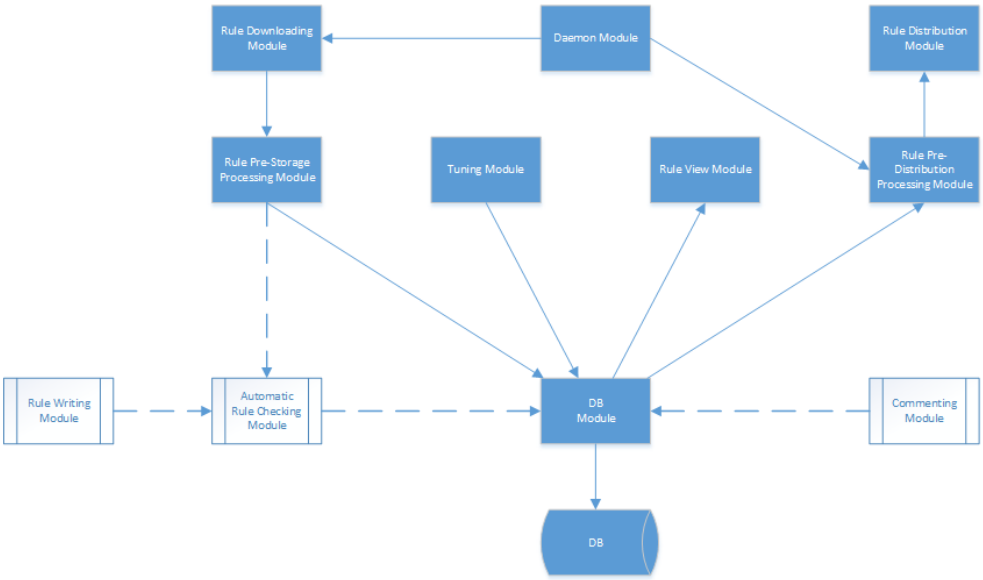


Figure 3: Program Modules

Rule Download Module

This module will handle all functionality related to downloading rules, including comparing MD5 checksums.

Rule Pre-Storage Processing Module

This module will essentially take downloaded rules, and parse and process them into objects that can be fed into the database.

DB Module

This module will handle all input and output to/from the database.

Rule Pre-Distribution Processing Module

This module will essentially take rules stored in the database and prepare them for distribution to sensors.

Rule Distribution Module

This module will be in charge of distributing rules out to the Snort sensors and handing the rules over to Snort itself.

Tuning Module

This module will handle all functionality related to turning rules on or off, filtering them or suppressing them.

Rule View Module

This module will contain all the functionality needed to display the system status and system functions to the user. It will be the primary way the user interacts with the system. Basically the GUI module.

Daemon Module

This module will run continuously on the system to ensure that the system is responsive and to carry out any timed tasks, such as automatic updates or automatic distributions.

Commenting Module

This module will allow users to attach comments to rules.

Rule Writing Module

This module will handle functionality for writing custom rules and editing existing rules.

Automatic Rule Checking Module

This module will be responsible for verifying rules to ensure that there are no malformed or misconfigured rules that may potentially break or cause a halt on a Snort sensor.

3.1.2 Use Case Diagram

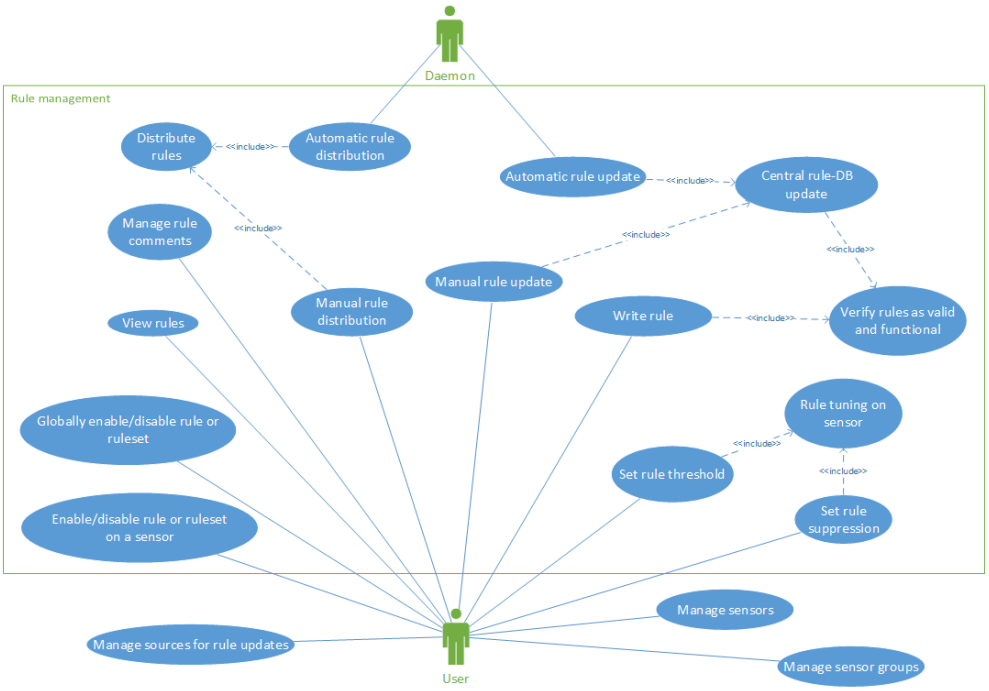


Figure 4: Use Case Diagram

3.1.3 Domain Model

After outlining all the concepts above, we outlined the concept model in Figure 5 of the objects we would need in the system. Even though a Snort rule is quite simple by

itself, there is a lot of meta information surrounding them, such as rule revisions and rule classes. Thus, our system needed at least 16 different classes in order to fullfil the basics of the required functionality.

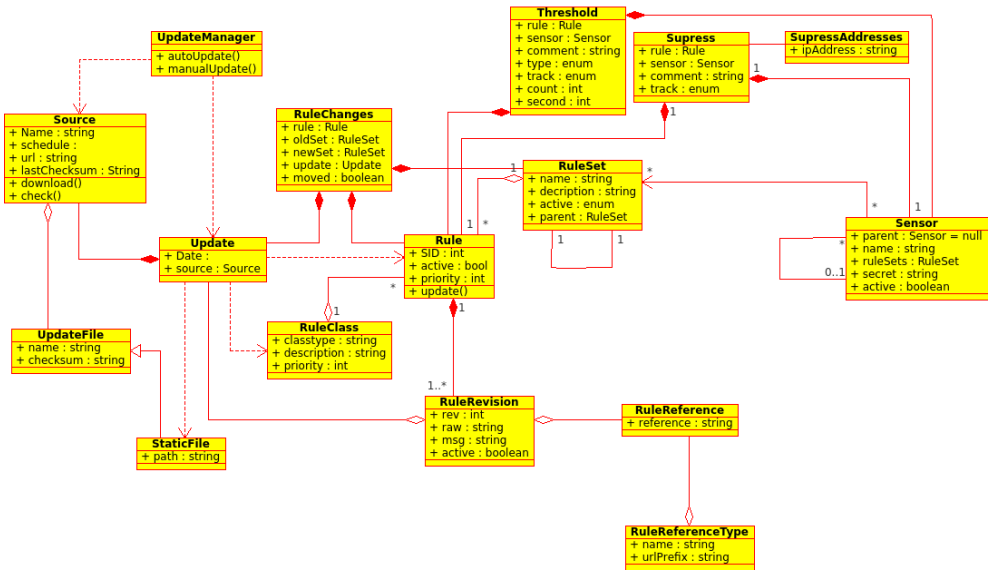


Figure 5: Conceptual Class Diagram

3.2 Supplemental Requirements

In addition to the features discovered in the use cases, we added some requirements we felt were needed, that can be broken down into a RUP FURPS+ fashion[23] .

3.2.1 Functionality

- The system should be able to restart a Snort sensor in the event that one crashes.
- The system should be able to detect if a Snort sensor is not responsive over the network.
- The system must be portable to the majority of the popular linux distributions. Porting to other operating systems, such as Windows, should be possible through changing the operating system specific code.

3.2.2 Usability

- The graphical user interface must be simple and clean, but still contain all the features any user might require to interact with the back-end system.
- The system interfaces, herein API and function calls, must be self-explanatory.

3.2.3 Reliability

- The system must not cause a SNORT sensor to crash.
- The system must be responsive to API calls at all times. In the event the system capacity limit is reached, new requests should be queued.

3.2.4 Performance

- The system should handle administration of at least 200 sensors.
- The database should be able to maintain at least 100 000 individual rules.
- Any operation in the system in normal operations (i.e. after the first big rule update) should take no longer than 1 second on average.
- The relationship between time and workload should be sublinear, meaning that if a single operation takes 1ms, ten operations should take 10ms.

3.2.5 Security

- The link between the system server and the remote sensor must be secured in such a way that a man in the middle cannot read the transmission in plaintext.
- The remote sensor and the system server must verify that they are trusted parties in the system, through authentication.
- Certain important API calls must be protected against misuse from a non-trusted party.
- All processes and files related to the system must exhibit the principle of least privilege [24].

3.2.6 Interoperability

The system must be able to work with Snort in such a way that it can import new files to the Snort configuration files structure and must be able to reset Snort in such a way that the new configurations are loaded.

3.2.7 Licensing

The system will be released to the public as Open Source under the GNU General Public License v3 license[25].

3.3 Constraints

3.3.1 Platform

As mentioned in the project plan (Appendix A), Snort is primarily used in conjunction with the Linux/UNIX operating systems. For that reason, the project was restricted to only develop for that platform. More specifically, we limited ourselves to the Ubuntu and Debian operating systems, which are the primary platforms Avdeling BKI uses as well. We have, however, stived to make the software portable to most Linux distributions. A port to Windows should also be possible through changing some of the operating specific code.

3.3.2 Data security

While the system itself will not handle any data that may contain personal data, it may contain rules and rule sets that are considered classified or confidential. The system has therefore been built with this in mind and ensures confidentiality within the boundaries of the system. The system does not guarantee the confidentiality of the system outside these boundaries.

The boundaries are defined as the program and its processes and threads, and the network link established between the system and remote sensors. The system assumes that the users have already established database security.

3.3.3 Graphical User Interface

The project has had its main focus on the system functionality and efficiency, and developing a graphical user interface (GUI) has been considered a secondary task and was prioritized as such. None the less, a GUI for demonstrational purposes has been included.

3.4 Security Assessment

During the inital phase of the project, we conducted a small security assessment in order to be aware of and possibly fix any security issues the software might have. We created a simple risk analysis table of the potential weaknesses we could find, listed in Table 2.

Threat	Component	Consequence	Probability	Risk	Strategy
Unauthorized users change data through the API/Web-interface	API/Web	8	5	6,5	Authentication/authorization. Django support for users and authentication.
An unauthorized user gains direct access to the database and is able to alter the data.	Central database	10	1	5,5	Assume database security is in place.
Continually sending requests to the server, filling it up with requests to the point of causing a denial of service.	RPC Server	7	4	5,5	Authenticate requester, Rate-limiting on requests, logging.
An attacker inherits escalated privileges through exploiting the software if it is run as root or other high privilege user.	All processes	8	3	5,5	Follow least privilege principle. Python also protects against buffer overflow
The SID/Rev of a malicious rule is newer than an existing rule, with the purpose of overwriting the existing rule.	Update module	7	2	4,5	Add possibility for the user to see changes before they are commited.
In a scenario where the database is not on the localhost, a man-in-the-middle attack is possible.	Central database	6	3	4,5	Assume database security is in place, encrypt transmissions.
Continually sending requests to the sensor client to update itself, filling it up with requests to the point of causing a denial of service.	RPC Client	5	4	4,5	Limit the allowed update frequency, logging.
Some unauthorized machine poses as a legitimate sensor and gains access to rules through update requests.	RPC Server	5	2	3,5	Authenticate the sensors.
During an update, one or more rules contains errors that causes Snort running on a sensor to crash or shut down.	Update module	8	4	6	Verify the rules.
A rule file is specially crafted to contain an SQL injection.	Update module	10	2	6	Use prepared statements and never let input directly touch the database.
SQL injections, XSS og CSRF (cross site request forgery)	API/Web	5	5	5	Django has support for protection against these attacks. Validate input.

Table 2: Security Assessment

4 BASICS OF IDS AND SNORT

This chapter gives a brief introduction to the basic concepts of IDS's in general and Snort in particular.

4.1 Rules

A Snort rule is made up of a header section followed by rule options. The header specifies which network, protocols and ports the rule is valid for, and which action to take if the rule matches traffic, while rule options provide metadata for the rule, such as its ID and classification [18]. The rule options are specified as plain text in the *rule string* enclosed in parentheses (Listing 4.1). Note that a badly formatted rulestring given to Snort will cause a crash.

```
alert udp $EXTERNAL_NET any -> $HOME_NET 69 \
(msg:"PROTOCOL-TFTP Get"; classtype:bad-unknown; \
sid:1444; rev:9;)
```

Listing 4.1: Example rule string.

There are several types of rule options, but only the general rule options are relevant for this project. The general rule options provide information about the rule [18] (i.e. signature ID, revision number and classtype). Other types of options, such as payload options, which are actively used in detection, are not relevant for the management of rules and are thus not considered in this project. Some of the general options can only be specified within the rulestring, referred to as *inline* specification, while others can be specified in separate files, referred to as *external* specification.

A rule can either be enabled or disabled in the detection system, meaning that the rule will only have an effect on detection when it is enabled. Since this project is dealing with multiple sensors connected to one central database, this functionality has been expanded so that users can keep a rule enabled on one sensor and disabled on another. In addition, the user can also set an enabled/disabled flag on *rulesets*.

4.2 Rulesets

The term ruleset, sometimes rule set, is not formally defined in the Snort Users Manual, however it is used a few times to refer to the complete collection of official Snort rules[1] and to the complete set of rules applied on a Snort system. In practice, rules are categorized by intrusion type (e.g. malware, trojan and worm) in order to keep the rules structured. These groups of rules are often named by their intrusion type, and are also referred to as rulesets. Snowman and this report use only the latter definition of rulesets. The official Snort rules are split into files whose names denote the ruleset.

4.3 Generators

Generator is a term used for any subsystem of Snort which generates alerts from rules [18]. Each generator is identified by a unique generator ID. The rules subsystem, which

[1] Also referred to as the Sourcefire VRT Certified Rules, see http://www.snort.org/snort-rules

has generator id 1, is the only relevant generator for this project.

4.4 References

Snort contains a plugin which allows rules to contain references to external attack identification systems, which provide additional information about the alerts [18]. A reference is basically a URL string pointing to a webpage containing this information.

4.5 Event and detection filters

Filtering can be applied to rules in order to control the amount and frequency of alerts. Two types of filters can be applied to a rule: event filters and detection filters. A detection filter can only appear inline, whereas an event filter can only appear as a standalone option[2]. All filters operate with a *count* and *seconds* variable, representing the number of events in a time interval and the duration of the time interval, respectively. Event filters are further divided into three types (table 3).

Detectionfilters are filters limiting the number of times a rule generates an event, while eventfilters limits how many events are producing alarms.

4.6 Rule suppression

Some rules might match traffic that is unwanted from most hosts, while some hosts would be allowed to send traffic matching the same rules. In this case, Snort gives the possibility to remove (ie: suppress) alarms when the source or destination of the traffic matches the configured parametres.

Filter type	Alerts
Event filter	
Limit	One for every event when number of events $\leq$ C in interval S
Threshold	One for every C events in interval S
Both	One per interval S when number of events $=$ C
Detection filter	One for every event when *count* $>$ C in interval S

Note: C and S represent the count *and* seconds *values in the filter.*

Table 3: Effects of different filter types.

[2]An event filter can currently be written inline (called a rule threshold), but according to the Snort Users Manual this feature is deprecated and will not be supported in future releases.

5 DESIGN

This chapter will present the design specification of Snowman.

5.1 General Design

This section is dedicated to the discussion of the general design of Snowman.

5.1.1 Centralized or Distributed Setup?

We decided early on to design Snowman to be a distributed system. The main considerations behind this choice were the bandwidth usage needed by the rule updates, and the load on the central server.

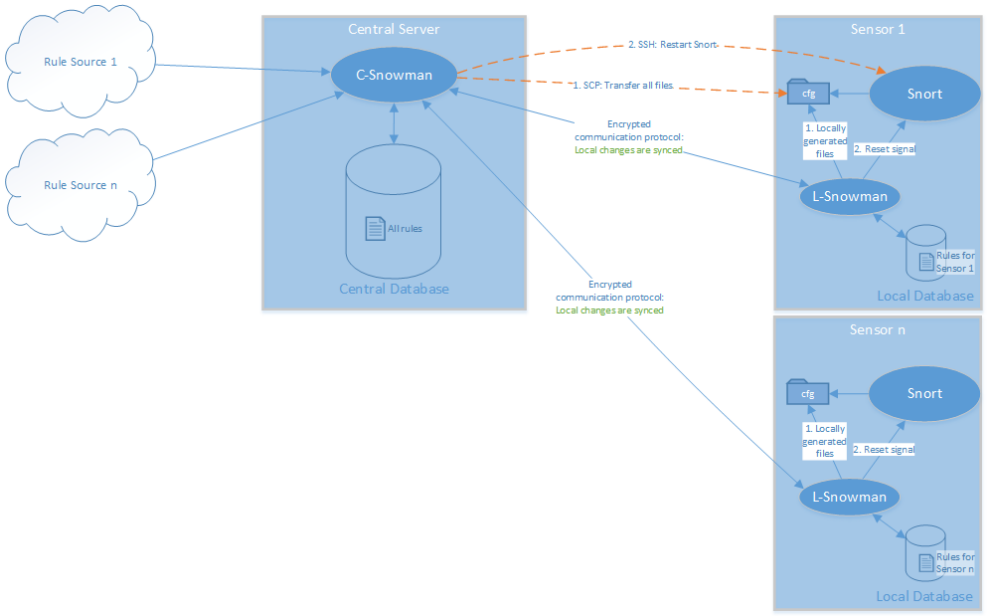


Figure 6: General architecture

In Figure 6 we can see the difference between a centralized and a distributed setup. The red dotted lines represent the communication in a centralized setup, while the blue lines between the server and the clients represent the communication in a distributed setup. The latter is the principle used in Snowman.

Bandwidth Requirements

The Snort sensors managed by Snowman might have varying network infrastructure connecting them with the central server. In a worst case scenario, the sensor might be located at a military base in the field, on the other side of the planet, only connected to the central server via a satellite connection with limited capabilities for transmitting data. As the rulesets applied to sensors typically consist of tens of thousands of rules and the changes between two versions of the sets typically only affect about a thousand of them, it seems

reasonable to only copy the changes when an update should be done. This is achieved by using a distributed system.

Central Server Load

When a full update of all the sensors is requested, new rulesets would have to be created and distributed to the sensors.

In a centralized environment, the central server would need to generate all the new rulesets and send them to the sensor. The server would not know beforehand which rules currently exist on the sensor, so a full list of rules would need to be sent, even if there were no changes to any of the rules. Also, if the sensor for some reason is unavailable, or connected through an unreliable network connection, the central server would waste a lot of extra effort to send the rules to the sensor, even if it is not neccesary as no rules have changed.

In a distributed environment, we would be able to put some logic (a client) into the machines hosting the sensors. This way, when an update is occurs, the client can get a list of rules from the central server, and on its own accord be responsible for collecting the new revision of the rules that have changed or are missing. In this way, the central server would only need to transmit the rules from its database if the rule is actually needed by the sensor.

5.2 Server Design

The server is the central component of Snowman and generally consists of:

- Central rule storage
- Web interface for user interaction
- Update-module to get updates from rule sources
- RPC interface to communicate with the clients

The central storage of rules would be in a normal relational database. As we have decided to use Django (described in chapter 6) as our framework, we have a great flexibility in choosing the database we actually use. In the current version of Django (1.6) we have support for MySQL, PostgreSQL, SQLite or Oracle.

For the RPC interface, we have decided to use XML-RPC. This is a very simple protocol using XML over HTTP to transfer requests and data to and from the server. To be able to keep up with the aspect of privacy and security, we encrypt the raw HTTP stream using SSL.

5.2.1 Architecture

We have designed the server by the layered approach of MVC (Figure 7).

The web-interface uses pure Django logic. The HTML visible in the web browser is generated by the Django template-engine, which recieves its data from the views created by using ordinary Python code.

The XML-RPC server uses a handler which administers the connections to and from the sensors, and exposes the relevant methods to allow the sensors to perform synchronization.

The update module is used for unpacking and preparing the update files for parsing. It then handles the files to the parser. This parser is then tasked with translating the raw

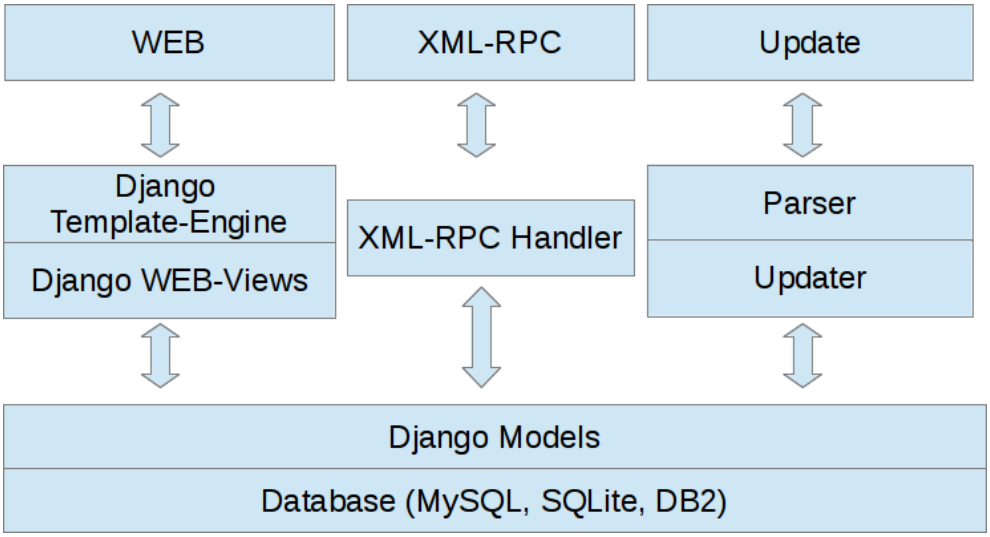


Figure 7: Server Architecture

rule files into more managable data structures for the Updater, which in turn saves them to the database.

Finally, common for all the interfaces are the Django Models. We use the database abstraction layer provided by Django to map the rows of a relational database into Django objects. This is the part that lets us write code, which is compatible with several different database engines.

5.2.2 User Interface

The main user interface for Snowman is the web interface. It is based on Django's template system, which generates the HTML that is displayed in the web browser on the user's computer.

URLs

The first step of serving a page to a user is an HTTP request for a specific page. The pages are uniquely identified by URLs, such as '<server address>/web/rules/'.

The URLs are structured in a logical manner, where everything in the web interface is found under /web/, everything regarding the administration of rules is found under /web/rules/ and so on. The URLs might contain dynamic data, such as page numbers (e.g. /web/rules/rules/page/3/ which will give you the third page of the rule-list), so that dynamic content can be loaded when needed.

Django uses the URLs to identify which view the requested url corresponds to. When a view is identified the request is passed to the corresponding view.

Views

The views constitute the part of the user interface that collect the required data from the models-layer and then generate a response to the web client. The response can contain a full web page, or just a small subset of one.

The typical steps a view makes to generate a response would be:

1. Collect the required data from the database(s) using the Django models.

2. Deliver the collected data, and a template, to the template-engine to generate the HTML representing the webpage the user requests.

3. Send the created web page as a response to the user.

The view system decides what to show and then lets the template system decide how to show it. The view system by itself does not create any HTML or similar. It solely creates data structures.

If the request was for raw data and not a webpage, step 2 in the list above might be skipped, and instead return the data as some form of recognizable data structure in step 3.

If errors occur in the view system, appropriate exceptions can be raised that tell Django to return an error code or an error page to the user instead of what the user requested.

Templates

When the view system has prepared all the data, the template system takes over. The task of the templates is to take the supplied data and inject it into pre-made skeletons of HTML. This way, all the design/display parts of the web interface are contained into one single and separate place, and that gives us a very clear line between data and design.

5.2.3 Database

As the database of the server is quite complex, we have divided the drawings, so that we have one drawing per module.

Core

The core database architecture used for storing the rules is described in figure 8.

The most central part of our system is the representation of a Rule. A single Rule might have several Revisions, as we might want to keep some history when they get updated. Each Revision has its own set of References attached.

A single Rule also has a lot of other properties which it might share with other Rules. A Generator, a Classification and a Ruleset are examples of such.

Finally, the Rules are assigned to a Sensor by attaching Rulesets to the Sensor.

Tuning

In addition to storing the raw rules, we would like to be able to store tuning parameters on the rules. As sensors might have different tuning parameters, we cannot attach the tuning directly to the rules. Separate tables (as described in Figure 9) are thus needed to model the tuning parameters.

Both types of filters and the suppressions are connected to a Rule and a Sensor. This way, we let the user specify filters for the individual sensors. If a sensor does not have a filter applied, but any parent sensor of that sensor has one, the closest parent's filter will be applied.

Update

When rules are inserted into the database, we would like to have some traceability to be able to determine where and when a rule has entered our system. To be able to do this, we have the update object (Figure 10).

The structure of the Update module allows us to store the update sources, and adds a new Update object to each update executed from a given source. These Update objects

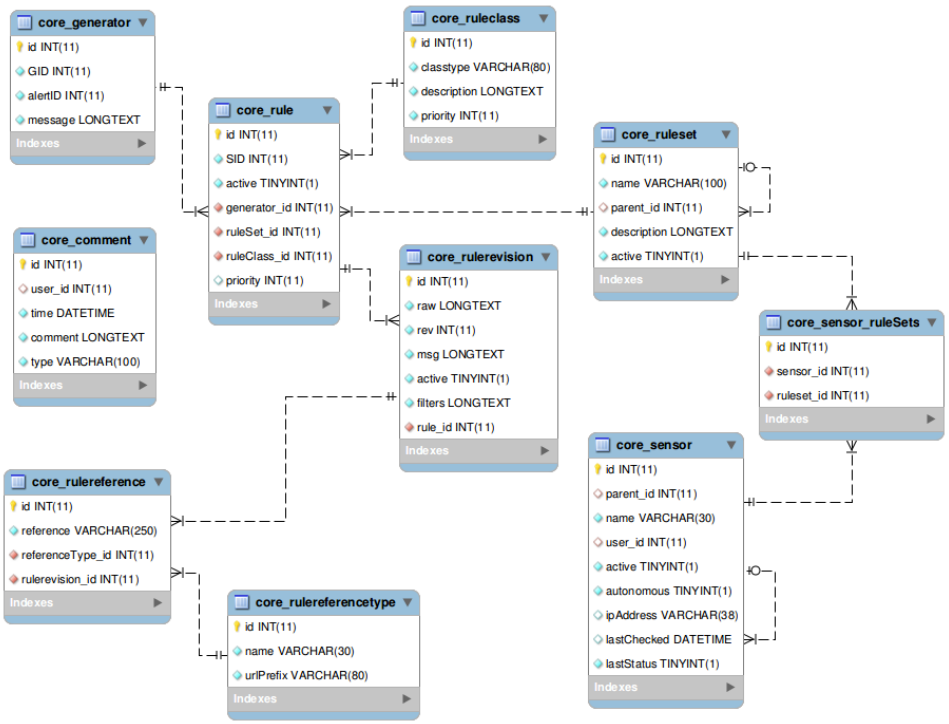


Figure 8: Core server-database

can in turn have relations to Rules, RuleSets and Rule Revisions, so that we can track changes for each update.

5.3 Client

As the client is just going to take care of getting rules for a single sensor from the central server and should just apply these to one sensor, the architecture of the client can be much simpler than that of the server.

5.3.1 Architecture

The MVC architecture for the client can be seen in figure 11.

The update handler of the client has both an XML-RPC Client and an XML-RPC Server. The XML-RPC Client is used to connect to the central server to do a rule synchronisation. The XML-RPC Server is here so that the central server can connect to the client and check to see if the client is active or to order the client to perform rule syncronisation.

As the client should be as lightweight as possible and the only aspect we need from any framework is a simple database connection and abstraction layer, so we have decided to not use Django for the client. Instead we use the database ORM [26] for Python called SQL-Alchemy [**?**], which is much more lightweight than Django for this purpose.

The client also contains a file creator which takes the rules objects in the database and generates the files Snort needs in the format Snort needs them in.

5.3.2 Database

The database on the client can be significantly simpler than the one on the server, as we only care about the rules which should be present on a given sensor. The full database

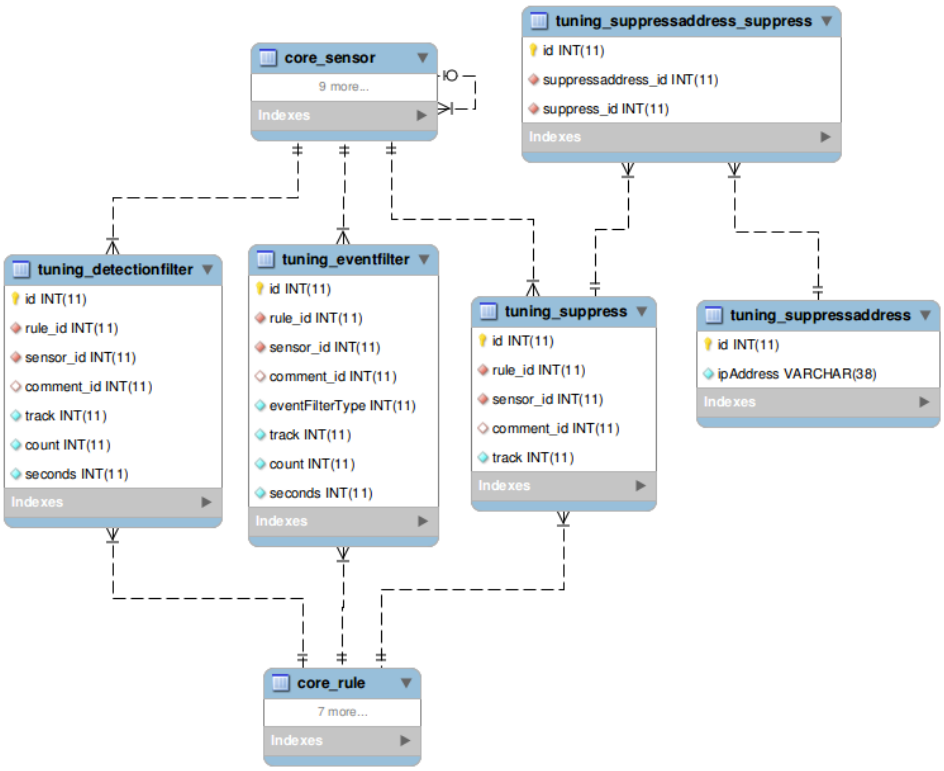


Figure 9: Tuning server-database

schema is available in Figure 12

The central part of the data structure is the rule table. This table contains all the parameters directly related to the rule. In addition, we have separate tables for all the meta parameters surrounding the rule, such as rulesets or filters.

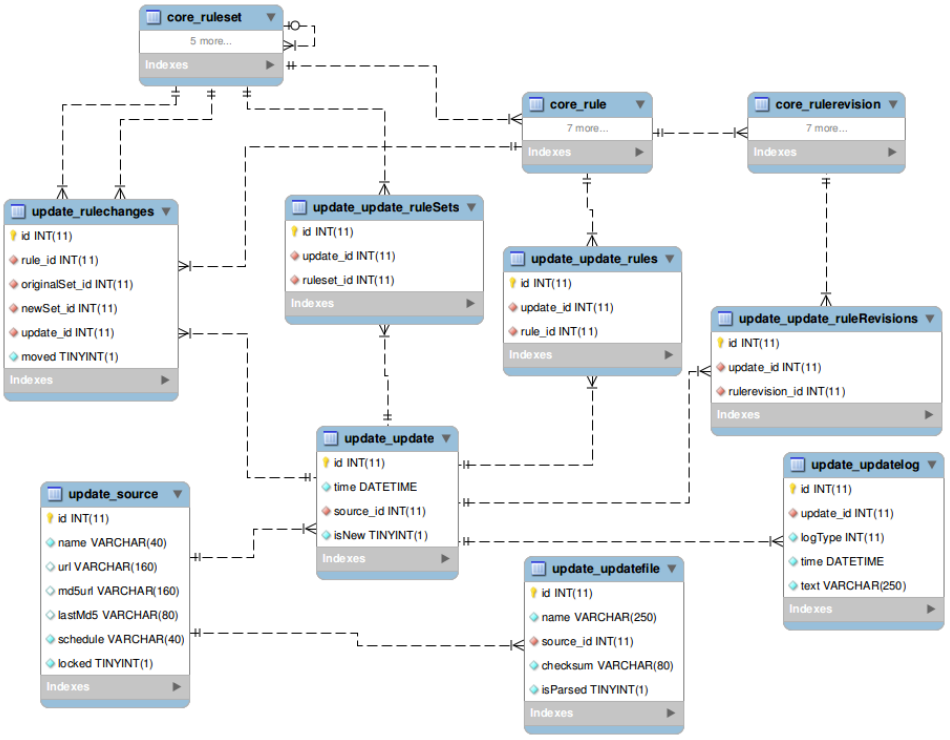


Figure 10: Update server-database

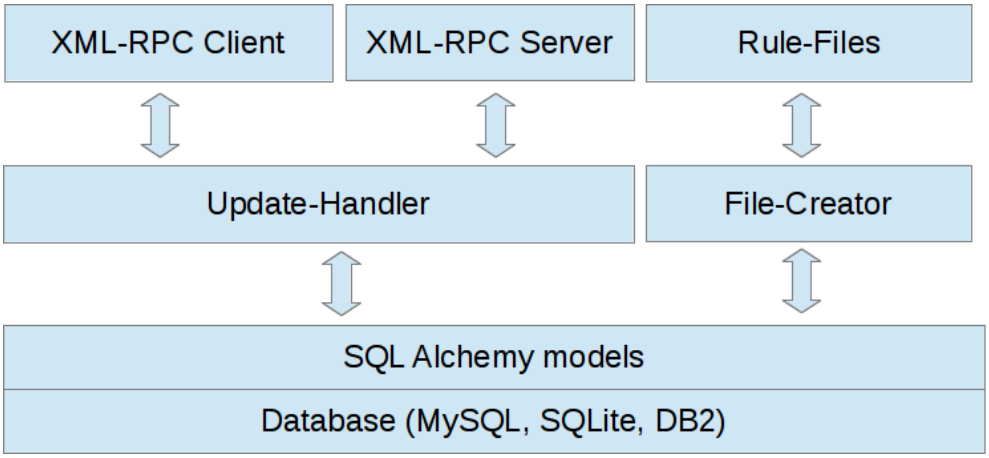


Figure 11: Client Architecture

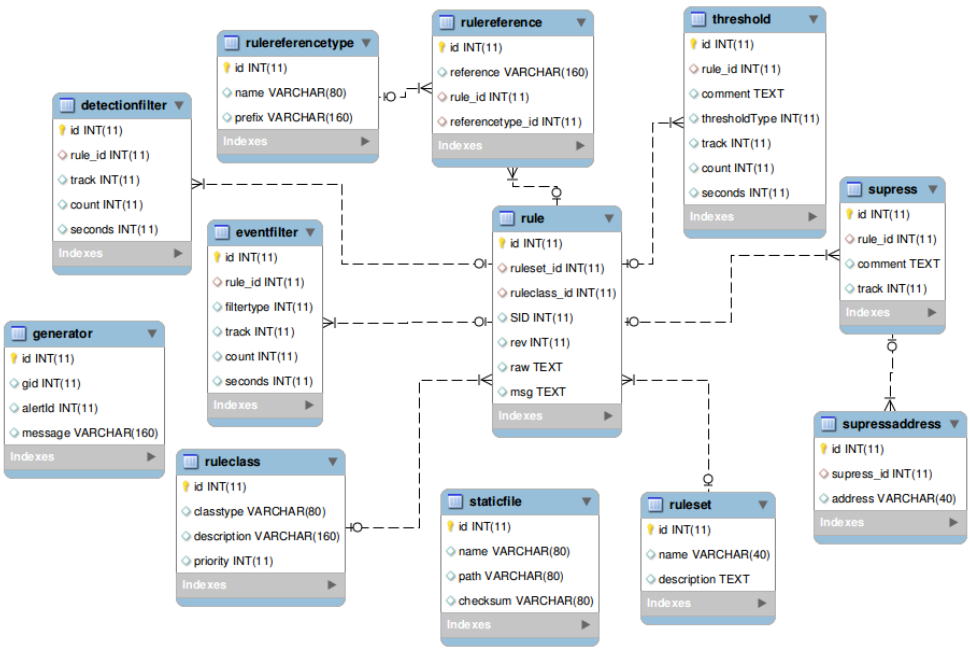


Figure 12: Client Database

6 IMPLEMENTATION

This chapter focuses on the technical implementation of Snowman. The first sections cover programming languages, development tools and frameworks used in this project, followed by a description of the most important modules of the server, including the GUI. Application logging and the documentation and deployment of the software is covered at the end of the chapter. Some sections within this chapter require general knowledge of the key concepts of Snort described in Chapter 4.

6.1 Programming Languages

Snowman is primarily written in Python 2.7 [27]. The project group landed on this decision after discussing the aptness of C, C++, Java and Python to this project, with regard to development and processing efficiency. Due to the limited time-frame of this project, it was vital to get right into the development without having to learn a new programming language or unfamiliar programming concepts. It was also important to find a language which produces high performing programs, since this project aims to be more effective than similar software. The C and C++ languages were considered because these languages can produce programs with very high performance, however, these were abandoned as we concluded that they would induce more work because of their complexity, and thereby be too time-consuming.

The final decision fell on Python mainly because of this language lets the programmer develop complex programs in a short amount of time. Python has automatic memory management and offers a wide range of built-in tools, which gives the developers time to focus more on the code and functionality rather than overhead tasks like managing memory and including external libraries. A concern was raised that Python, being a high-level language, might not be efficient enough for this project. This turned out to not be a problem, as Python can run modules written in C. A major reason for using Python was also Django (see section 6.3), which is a Python framework used in this project that greatly simplifies database transactions and generation of web pages.

The most current version of Python available at the start of this project was version 3.3. The project group selected version 2.7, as a break in compatibility [28] between 2.X and 3.X versions of Python cause some problems. According to a recent survey [29] Python 2.X still holds a dominant position among developers, five years after the release of Python 3.0. According to [28], version 3.3 has slightly worse library support. The continuing popularity of 2.X versions implies that many packages are still being developed and maintained for these versions, and these versions only. One example of this is the aforementioned Django framework which is heavily used by Snowman. Development using Python 3.X with Django is possible with the use of a compatibility layer [30], but the project group considered this as a bit cumbersome. Taking into account that the majority of the group was already comfortable with Python 2.X, this came out as the most time-saving choice. The biggest drawback of this decision is that it does not make Snowman future-proof, and it will probably have to be ported to Python 3.X in a long-term perspective.

For Web-programming, this project has used HTML and CSS for the design and JavaScript for client-side scripting.

6.1.1 Standards and Guidelines

Python imposes a strict indentation regime, as this is actively used in the syntax to delimit blocks of code. The project group has followed standard Python guidelines for best practice programming, with principles as DRY[1] and EAFP[2] (the latter actually caused some unforeseen performance issues described in Section 6.5.6).

Documentation has been a high priority. The project group has aimed to make the code self-documenting by utilizing sensible names on variables, functions and classes to enhance the reader's understanding. As a general rule, variable names are written in camelcase[3]. With a high focus on development, the project group has taken advantage of Python Docstrings [31] (documentation strings) which are incorporated into the code, and can therefore be written at the time of coding without taking the focus away from the programming. The Docstrings describe how the code is used, and form the basis of Snowman's documentation. Listing 6.1 demonstrates the EAFP-principle, also note the use of a Docstring at the beginning of the method.

The Python manual encourages the use of exceptions, which is a useful way of sending messages up the execution stack when an error or irregular behaviour is deceted. Customized exeptions are raised in Snowman for example when parsed data has a wrong format (*BadFormatError*), when critical objects are missing from the database (*MissingObjectError*) or when an unsupported rule is encountered (*AbnormalRuleError*).

Writing object-oriented code has not been a goal in this project, but concepts such as encapsulation, polymorphism and inheritance have been applied when needed.

```
1  def getSecondMessage(messages):
2    """Returns the second message from messages or
3    empty string if second message does not exist."""
4
5    # Below code demonstrates the principle of
6    # EAFP (1) versus LBYL (2); The execution
7    # of block 1 is faster than block 2 when
8    # message[1] exists. Block 1 is therefore
9    # preferred whenever the try-block is
10   # expected to succeed without an exception.
11
12   # Block 1, EAFP:
13   try:
14     message = messages[1]
15   except IndexError:
16     message = ''
17
18   # Block 2, LBYL (look before you leap):
19   if len(messages) >= 2:
20     message = messages[1]
21   else:
22     message = ''
```

[1] "Don't repeat yourself". The principle that code should not be duplicated in a project.

[2] "Easier to ask for forgiveness than permission".

[3] A style convention where multiple words are written as one, with the first letter of each word capitalized, e.g. getAllRules.

```
23
24    return message
```

Listing 6.1: The EAFP-principle.

6.2 Development environments

This section describes the various development environments and tools used in this project.

6.2.1 Environments

Snowman is developed on and for the Linux platform. Eclipse [32] was selected as the default development environment, as this is freely available and contains the major features required for effective development such as project management, a Python editor and a debugger (available with the PyDev add-on). PyUnit has also been used for unit testing. In addition, the TeXlipse and PDF4Eclipse add-ons for Eclipse have been used to write and generate this report with Latex [33]. Since Python is an interpreted language, the Python interpreter has been used throughout the project to test and debug code segments. The user interface has been mostly programmed for and tested in the Chrome web browser as it has a very good built in debugging environment, but limited testing has also been conducted on Firefox and Internet Explorer.

6.2.2 Version control

This project has used Subversion (SVN) provided by the IT department at Gjøvik University College for keeping version control for all project files. This includes all source files and project documents such as design documents, meeting minutes and the report. The SVN repository hosted by the IT department has also been used to ensure that data is not lost.

6.3 Frameworks

To prevent re-inventing the wheel to many times, we have decided to use several frameworks to help us do generic tasks.

6.3.1 Django

To facilitate database transactions and the creation of the Web interface, this project uses the Django [34] framework. Django is an extensive web-framework, designed to make the full process of building web-based applications and their backends much more efficient and simple. It takes care of the database ORM, which controls all the database-transactions. Django is also providing a template-system for the web-frontend, which make a clear line between the data and design of the webpage.

6.3.2 SQLAlchemy

A database ORM would also be needed on the Snowman-client, but the rest of django is not needed there. Because of that, SQLAlchemy is used on the client.

The SQLAlchemy framework is creating an abstraction over the database, and lets us develop the code once, and still let the user decide which kind of database to use on the client.

6.3.3 jQuery

When it comes to using JavaScript for client-side scripting, jQuery [35] is a good solution, as it provides a framework for common JavaScript operations on the DOM[4] and contains abstractions for a lot of browser-spesific code, which gives programmers a nice and clean interface. It also makes AJAX-calls[5] a lot easier, requiring much less code compared to regular JavaScript (example in Listing 6.2).

```
1  // AJAX call in jQuery:
2  \$.get('/web/rules/');
3
4  // AJAX call in JavaScript:
5  function loadXMLDoc() {
6      var xmlhttp;
7
8      if (window.XMLHttpRequest) {
9          // code for IE7+, Firefox, Chrome, Opera, Safari
10         xmlhttp = new XMLHttpRequest();
11     } else {
12         // code for IE6, IE5
13         xmlhttp = new ActiveXObject("Microsoft.XMLHTTP");
14     }
15
16     xmlhttp.onreadystatechange = function() {
17         if (xmlhttp.readyState == 4 && xmlhttp.status == 200) {
18             document.getElementById("myDiv").innerHTML = xmlhttp
                   .responseText;
19         }
20     }
21
22     xmlhttp.open("GET", "/web/rules/", true);
23     xmlhttp.send();
24 }
```

Listing 6.2: AJAX call in jQuery and JavaScript.

6.3.4 Bootstrap

To facilitate the design and appearance of the web interface, this project uses Bootstrap [36], which is a front-end framework derived from Twitter. It provides a lot of ready made CSS and design elements that make a web page responsive and typographically readable. Consider the example job of creating a <**table**> element and spending hours setting up and tweaking the CSS for the said table element, we could just add <**table class**=‘**table table**–bordered‘> and get the table formatted nicely with colors and fonts that are typographically matching.

6.4 Core module

This section focuses on the classes and methods in the `core` module. This module contains the most vital classes of the Snowman server including **`Rule`** and **`RuleRevision`** which hold the data of each rule in the system. Simple classes in this module such as **`Generator`**, **`RuleReference`** and **`RuleClass`**, which are connected to the **`Rule`** class are

[4] The webpage content or elements.
[5] AJAX is web development technique that allows you to send asynchronous requests to a web server.

only briefly explained in this section. For an overview of all objects in this module, refer to the class diagram in Section ??.

6.4.1 Rules and rule revisions

Rules in Snowman are split into two parts; the rule and the rule revision. As threats change, or errors in the rules are discovered, a rule may become obsolete and a new revision of the rule is released. The rule string, message and detection filter might change from one revision to the other, and are stored in the rule revision object along with the revision number. A revision is always connected to a rule object, which contains data that is constant for all its revisions, such as signature ID and rule set. The reason behind keeping rules and revisions in two separate objects is to avoid writing the same constant rule data for all revisions. Users of Snowman have the possibility to control how many revisions to store per rule, and whether incoming revisions should be active or inactive by default. This feature allows users to control automatically downloaded rules before they are put into the detection system. Users can also manually activate or deactivate rule revisions, and Snowman will distribute only the newest active revision of a rule.

6.4.2 Rulesets

As stated in Chapter 4, the categorization of rules in rule sets is a de facto way of organizing rules. The community rules[6] contain rules with a "ruleset" option within the "metadata" option in the rule string, which specifies the rule set. In other releases, rules are organized into files where the file name denotes their rule set. These two ways of specifying the rule set are both supported by Snowman.

6.4.3 Sensors

Every sensor in the system is represented in the database with its name, IP-address and status. Sensors also contain a list of rule sets applied to them, and active rules within these rule sets will be distributed to the sensors given that the rule sets are also active. A sensor can be configured to be autonomous, meaning it will not communicate with the server. Autonomous sensors can be used in environments where contact between the server and sensor is unwanted or not possible. Rules can be manually exported for these sensors.A sensor can also be the parent of other sensors, allowing users to create groups of sensors with the same configuration. The database also contains an "All Sensors" object, which is the parent of all sensors.

The sensors that is not autonomous is checked to be alive every minute, and the last registered status is stored in the database. This is then used to give a status-message for the sensor to the user. Each sensor does also have a user assigned to it. This user is used to let the sensors authenticate with the Snowman server to do a rule-synchronization.

6.4.4 Comments

The `core` module contains a comment object, which can store comments from users who wish to document their operations, e.g. the user can attach a comment when adding a filter to a rule to describe why the filter was added and which effects it will have on the system. Snowman can also generate comments for important events, such as turning rules and rulesets on or off, editing and deleting sensors, etc.

[6] "The Community Ruleset is a GPLv2 VRT certified ruleset that is distributed free of charge without any VRT License restrictions" - http://www.snort.org/snort-rules/

6.5 Update module

The purpose of the `update` module is to fetch and read rules and configuration files from external sources, and populate the database with this information. Effectiveness in updates is a key issue, and a number of deliberate optimizations for performing updates, with the goal of saving time by omitting unnecessary operations, are explained in the subsequent sections. To avoid confusion with the module, the term *update-package* is specifically used to refer to update data coming from external sources.

6.5.1 Sources

A *source* is a provider of update-packages. Snowman lets users define sources, which are either external (i.e. online) or local, meaning that the update-package will either be downloaded from the web or read from the local system. All information about each source is contained in the `Source` class. The sources determine where the update-packages are located, and an update-package must always come from a specific source.

External sources contain a URL pointing to the location of the update-package, and alternatively also a URL to the MD5-hash of the package. External sources can be configured to pull updates at regular intervals, contrary to local sources, which must always be updated manually.

A source can be configured to update at regular intervals, or the user can run an update manually on a source. To make the update process more effective, `update` makes use of an MD5 URL which points to a file containing the MD5 hash of the update-package. This hash is stored for every source (if available) and is compared to any pre-existing hash to verify if the system is up to date or not. `update` will only download and process an update-package when it encounters a new hash.

6.5.2 Files

An update-package may contain various files depending on the source it comes from. This section describes the files supported by Snowman. Note that file names and extensions used in this report follows the *de facto* names used in the official Snort rules, but are subject to change. The names and extensions can therefore be manually specified by Snowman users in a configuration file (section 6.10).

Rule files

A rule file is any file carrying the *.rules* file extension. These files contain raw rule strings to be processed by Snort. A rule string is basically a semicolon-separated list of rule options. Specific rule options used in this system are listed in table 4.

Classification, Generator and Reference Configuration files

The classification files are identified by their name *classification.config* and contain rule classification strings that are used by Snort to categorize event data. A classification file will normally appear once per update-package, and rarely changes between updates[7]. Generator (*gen-msg.map*) and reference configuration (*reference.config*) files also contain strings that specify generator massages and rule reference types, respectively.

Signature message files

Alert messages for rules are normally written inline, but can also be specified in a file called *sid-msg.map*, which may also contain rule references.

[7] https://www.snort.org/vrt/snort-conf-configurations/

Data field	Description	Presence
sid	Unique identifier for a rule.	required
rev	Rule revision number.	required
msg	Notification text when rule triggers.	required
classtype	Connects the rule with a specific class of attacks.	required
gid	Generator ID to identify which subsystem generates the event where this rule fires.	optional
ruleset	The ruleset this rule belongs to.	optional
priority	Override default severity set by classtype.	optional
reference	Reference to external resource with information about this attack.	optional

Note: The *presence* column indicates whether a field is required or not by the parser in this system. Information is gathered from the Snort Users Manual [18](ch 3.4).

Table 4: Rule options used in this system.

Threshold files

These files contain filter specifications for specific rules.

6.5.3 Running an update

An update is either triggered by the user, or automatically at regular intervals, for a given source. Regardless of how the update process is invoked, it follows the same procedure. As mentioned above, sources will often provide an MD5-hash of the update. When this is the case, the hash is stored in the database. Every new update will compare its own hash to hashes stored in the database, and if an identical hash is found this means that the update has been run before, and the update process is terminated. When the hash does not pre-exist in the database, or for sources which does not use hashing, the update-package is downloaded to a temporary directory.

Snowman accepts update-packages in the form of tar-archives[8] containing rule and configuration files, and also supports plain text files containing rules or known configuration entities[9]. Tar-archives are extracted, and folders are traversed recursively to locate files for parsing. In most cases the update-package will contain only minor changes in relation to its predecessor, e.g. only one file is different in the latest package, and parsing all files that has not changed would therefore be a waste. To address this issue and save processing time, the name, path and MD5-hash of every file is stored in the database per source. Every time the update module parses a file, it first creates a hash of the file and compares this with the respective file's hash in the database. If the file is present in the database and the two hashes are identical, the file is considered *not new* and is skipped. The following sections will elaborate on the parsing of files based on file type.

The update module contains one parsing method for each supported file type. Since all information in an update is plain text, these methods use regular expressions to fetch

[8] Files that contain compressed files.
[9] Generators, filters, references etc.

the content. For example, a generator configuration contains a comma-separeted list with a name, description and priority: *config classification: unknown,Unknown Traffic,3*, which are extracted from the string by using a regular expression and put into a RuleClass object which is later stored in the database. update also contains a method for parsing files containing unspecified entities, where each line if first parsed to decide which entity the data belongs to befor it is sent to the correct parsing function for the respective entity.

6.5.4 Rule parsing

A rule file is read line by line, and each rulestring found is sent to the rule parsing method. The rule string is then matched to a predefined pattern that will verify that the rule is valid and extract the data fields (table 4.

Rulesets

A rule always belogs to a ruleset, which can be specified in the raw rulestring. If the parser does not find this attribute in the rulestring, the filename is considered to be the ruleset name.

Filters

As mentioned in Chapter 4, rule filters may appear in rule strings (detection filters) or in external files (event filters). In addition to these filters, Snowman supports a filter type called *threshold*. A rule threshold defines a limit and/or threshold for the triggering of a specific rule, just like an event filter, but can be specified both inline or externally. Rule thresholds are deprecated, and support for this functionality will cease in a future version of Snort [18]. To maintain compatibility with current rules, Snowman supports reading inline and standalone threshold definitions.

All inline filters are removed from the rule strings and transformed into event filter and detection filter objects. This is done to prevent Snort from adding filters to rules when parsing the rule strings, as duplicate filters for the rules will cause Snort to crash. Any filters extracted from rule strings are written as plain text (i.e. as they appear in the original rule string) in the *filters* field of the `RuleRevision` object. This is to ensure that all the original rule options are stored, meaning that no data is lost or discarded.

Suppression

Suppressions can be applied any rules that might be giving off false positives or generating a lot of unneccessary alerts. There might also be cases where the traffic in question is legal on certain networks or to/from certain IP-addresses. Only one suppression can be applied to a rule on a sensor, but multiple IP-addresses or networks can be listed in the suppression in the syntax [1.2.3.4,4.3.2.1/24]. Rule suppression is always specified in external files.

Snowman features IP-address validation checking to make sure no invalid addresses are entered, by running a regex-match on the address before it is committed. The match will check for a valid IPv4 syntax in the range 0.0.0.0/0 - 255.255.255.255/32. There is currently no support for IPv6, but this can easily be added later.

6.5.5 Classification, Generator and Reference Type parsing

These files contain a sequence of their respective entities (section 6.5.2), and are all parsed in the same manner. If a given entity is not already present in the database, it is created and stored. If the database already contains the entity, the existing entry in the

database is overwritten.

6.5.6 Saving

Performance testing of update processing (see Chapter 9) showed that Snowman version 0.4 was very slow compared to other software. The reason for this was examined, and found to be a large amount of database calls spread out in the code. Snowman 0.4 saved every rule individually after a change was found and the objects were updated. This principle is demonstrated in Listing 6.3, where the method tries to fetch, alter and save a classification object, or create a new one if not found. This turned out to be a bottleneck, as updates could take hours on low-end hardware. To solve this, we split the methods of `Update` into two new classes: `Parser` and `Updater`, where the first would only parse the incoming data and send this to the latter which gathered all objects and wrote these in bulk when the parsing was complete. As can be seen in Chapter 9, this had a huge impact on performance.

```
1  from core.models import RuleClass
2
3  def updateClassification(type, description, priority):
4    try:
5      # Update existing classification
6      ruleclass = RuleClass.objects.get(classtype=type)
7      ruleclass.description = description
8      ruleclass.priority = priority
9      ruleclass.save()
10   except RuleClass.DoesNotExist:
11     # Add new classification
12     ruleclass = RuleClass.objects.create(classtype=type, ...)
```

Listing 6.3: Updating a classification in Snowman 0.4

As some of the objects refer to other objects in the database through foreign-keys, it is vital to store the objects depending on other objects after the objects they depend on are stored. A safe order to save them has been identified and the objects are saved in this order:

1. Generators
2. Classifications
3. Reference-types
4. RuleSets
5. Rules
6. RuleReferences
7. Suppresses
8. Filters

For every item in the list above the procedure is approximately the same. First, the objects received are attempted to be extracted from the database. The response from the database lets us identify which objects are new and which are changed. The changed

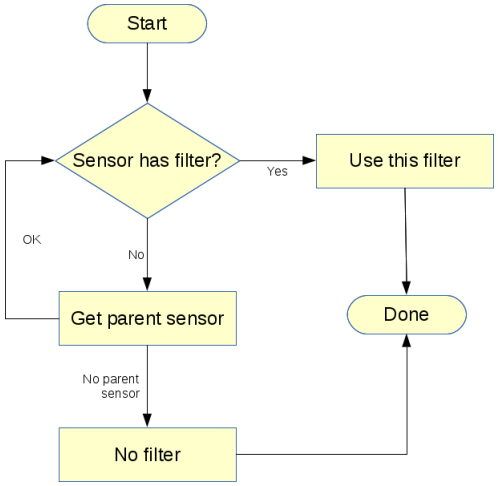


Figure 13: Applying a filter to a rule on a sensor

objects can be updated and saved individually before all the new objects are constructed and everything finally gets inserted into the database in one bulk operation.

6.6 Tuning module

The `tuning` module contains classes that hold information on rule filtering and suppression. Snort supports only one filter of each type per rule. In Snowman, this is translated to one filter of each type per rule *per sensor*, which means that a filter is always connected to both a sensor and a rule. If a filter occurs inline, this filter is regarded as a default filter and will be active on every sensor where the rule operates. This is accomplished by applying the filter to the rule and the *all sensors* sensor, which is the parent of all sensors. When a rule is enabled on a sensor, Snowman will look for any filter set on the rule on the respective sensor or on any of its parents. This means that a default filter can be overridden by setting another filter directly on the sensor. The routine for applying filters to a rule on a sensor is explained in figure 13.

6.7 Distribute

To distribute the rules from the central database to the sensors in a format that Snort can understand, three major events happen. Each of these are explained in the following three subsections.

6.7.1 Initiating the Distribution

Before a synchronization can start, the sensors need to know that they should synchronize. There are mainly two events that can cause a synchronization to occur:

1. Automatic synchronization based on time
2. Manually invoked trough the web interface on the Snowman-server

In the first case, the client itself knows that it should start to synchronize and therefore starts the authentication/synchronization procedure with the server. In the second case, the client does not initially know that anything happened. The central server has to

contact the client via the “snowmanclientd” daemon, telling it to initiate a synchronization.

6.7.2 Synchronization

When a synchronization is initiated the client connects to the “snowmand” daemon on the sentral server and authenticates with it. If the authentication is successful, the server knows that the sensor is who it claims to be and it also knows which rules the sensor should have installed. After this, the synchronization can start.

The first action is to retrieve all the `RuleClass` objects and update the local cache on the client to correspond to the retrieved list from the server. Changed objects will be updated, new objects inserted into the local database and obsolete objects will be deleted. Next, lists of `Generator`, `RuleReferenceType` and `RuleSet` objects are retrieved and the local database is updated in a similar manner as with the `RuleClass` objects.

For the synchronization of the rules, which is the main bulk of the data needed to be synchronized, a more efficient approach is used. First, a list of the signature-IDs and revisions of the rules that should be present on the sensor are retrieved from the server. If rules in the local cache are not mentioned in this list, or this list indicates that a new version of this rule is available, the rule is deleted from the local cache. Any tuning parameters belonging to this rule are also removed.

Next, the client starts to request the rules that it currently is missing from the server. To speed things up, this happens in bulks of 250 rules per request. This way, no single request gets too large and time-consuming. For the rules requested, tuning parameters like filters and suppressions is provided if the rules have rule tuning applied on the given sensor. References are also passed along with the rule.

All the received rules are then saved to the local database and the synchronization is complete. The final step of generating Snort configuration files is then started.

6.7.3 Generating Snort Configuration

The generation of the Snort configuration files is a rather simple process. First, the old configuration is cleared out and new files are generated based on the content of the local database.

The naming convention of the files is similar to the one SourceFire uses with their rulesets and the format of the files is exactly the same. This is to simplify the visual inspection of the rule files if that is desirable. It does not really matter to Snort which order the configuration files are in, as long as the content can be recognized as Snort configuration.

In addition to the various files created by Snowman, one file is always guaranteed to be generated. That is the “snowman-includes.cfg” file, which includes all the files generated. If Snort includes that file again, all the files generated by Snowman will be included for Snort.

Finally, when the configuration has been generated, the snowman-client sends a SIGHUP signal to the Snort process, which makes Snort reload its configuration and start using its new rulesets.

6.8 Graphical User Interface

The Graphical User Interface (GUI) is a template- and AJAX-based web application which uses Django’s template system to implement the View part of the MVC-principle[37].

Each webpage is a template populated through Python code before it is delivered to the Web server and ultimately the requesting Web browser.

Additional data that needs to be sent to a Web page, e.g. the user interacts with the GUI, is requested through JavaScript and AJAX-calls and then gets added to the already loaded DOM in the web browser.

6.8.1 Structure

The pages of the GUI are organized in the following structure, which is very similar to the way BHTB organized its front end.

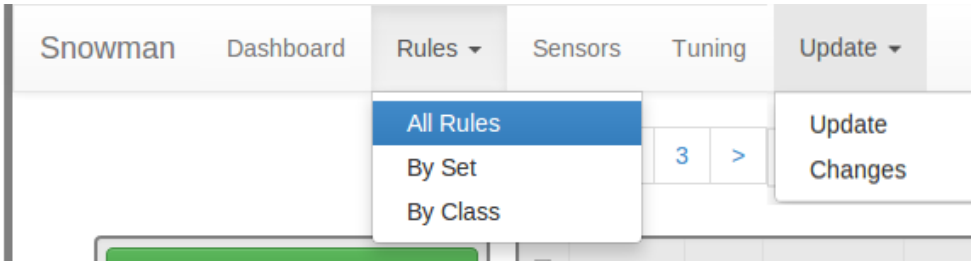


Figure 14: GUI Structure

6.8.2 Design

The GUI is designed with simplicity and minimalism in mind, which is achieved partially by using Bootstrap that has a lot of default no-nonsense design elements. But we also opted for a lot of primary colors and simple lines to make it easy on the eyes.

6.8.3 Overview of central GUI features

Content Prefetching

One of the main features of our GUI design is our usa of prefetching to speed up loading. Instead of loading absolutely everything into the web browser DOM, like our predecessor BHTB did, we instead initially only load the first page or page elements. This significantly reduces loading times.

We then silently in the background load in any element the user might want to see next, through AJAX calls. When the user then interacts with the GUI, the next elements are shown to the user. The next-next elements are also loaded through AJAX calls so that they are ready.

This ensures that the user always has immediate response from any interaction done with the GUI, while keeping loading times to a bare minimum.

Rules page

This page serves as the complete list of all rules currently residing in the central database. Because the central database can contain hundreds of thousands of rules, this list is paginated. Pages are loaded using AJAX calls to prefetch them as needed.

Each row in the list can be clicked on, which expands an area containing additional information about the rule in question.

We anticipate that the main use of this page is going to be utilizing the search function to find a specific rule or rules and then either retrieve information about them or otherwise manipulate them.

Rules can be tuned by checking the checkbox associated with the rule in question and

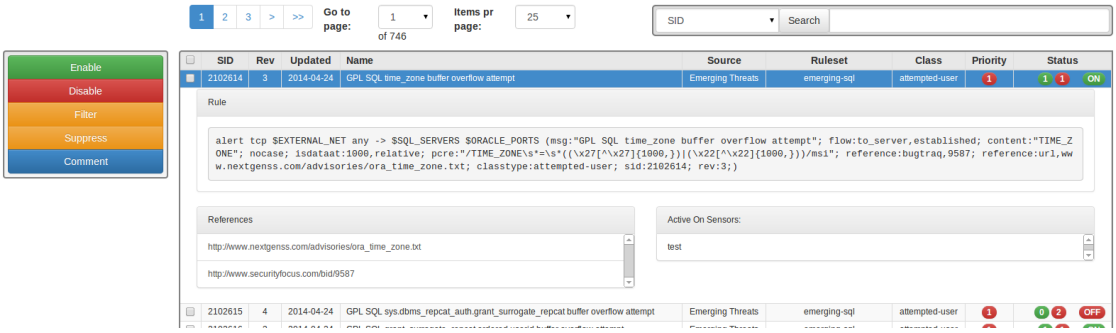


Figure 15: Rules page

then pressing the button that represents the desired function in the box to the left.

Rulesets page

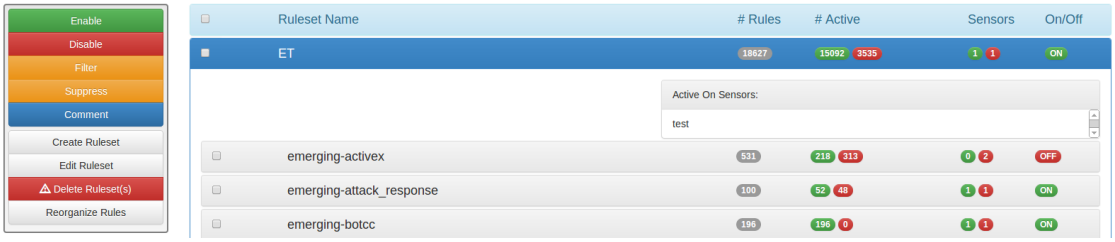


Figure 16: Rulesets page

The rulesets page consists of a list of all the rulesets stored in the central database. Each row contains meta information about the ruleset, such as the number of rules in the ruleset and so on.

A special feature of the ruleset page is that since Snowman allows the user to structure rulesets in a hierarchical tree, the ruleset list will initially only show the tree roots. If the ruleset has child rulesets associated with it, those will be listed once the user click on the ruleset and opens up the additional information area.

The list controls also contain functionality for creating, editing, deleting and reorganizing the rulesets, as well as the ability to turn them on or off either globally or on a per sensor basis.

We also have a very similar page for the sensor list, which also allows the user to arrange sensors in a hierarchical tree. Because it is virtually the same, it is not detailed in the report.

Updates and changes

One of the big requests from Avdeling BKI when it came to improvements of features of BHTB was the need to have more feedback over the update process, as BHTB only told you about the status after it was done, leaving the user without further information.

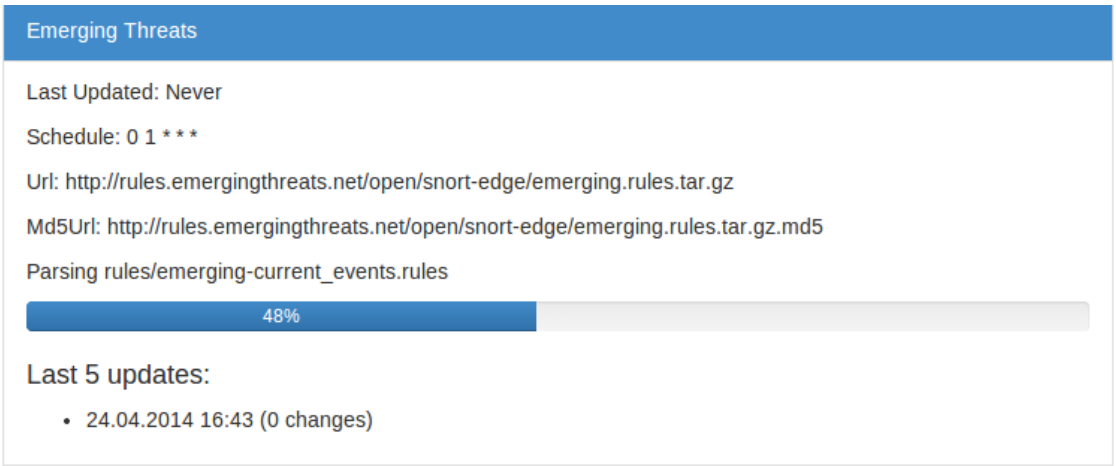


Figure 17: Update progressbar

To solve this, we added a continuously updating progressbar which tells the user what the system is currently doing and give a rough estimate of the percentage of completion.

Another requested feature was the ability to see what was changed during an update. We provide a list for this, which contains each update and its various changes.

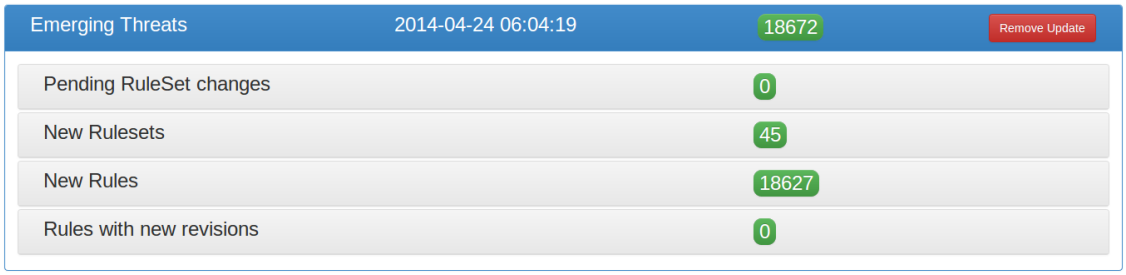


Figure 18: Update changes

The list details any new rulesets, rules or rule revisions an update might have brought with it, as well as a list of rules that have been moved from one ruleset to another. Once the user has finished checking out the changes from one update, the user can remove the update from the list. This makes the list a backlog tool, rather than a perpetually long list or some sort of time limited list (updates in the last 7 days or similar). This gives the user a good overview of what has changed since the last time the user checked the list.

Form validation and feedback

One challenge that web frontends always face are forms, as they are a means to alter data in the database and thus become a security challenge. So when we utilize forms, it is important to protect the database against both malicious attackers and user errors.

There are three basic steps to implement protection against these security issues, which is to:

1. Validate the data provided by the form.
2. Make sure the user cannot input something he/she should not.
3. To never let any raw strings or values from the form be directly inserted into a databasequery.

The third protection is the most important one as it prevents SQL injection attacks, which are attacks where SQL code is input into the form, letting the attacker carry out his/her own queries, leading to total database compromise. This problem is solved through a technique called prepared statements, which make sure a query does not do anything it is not supposed to before the query is actually executed on the database. This protection is implemented in our system through Django's internal protection mechanisms.

The first and second protection is something we have implemented ourselves in both our frontend and our backend. We make sure that the user can never input invalid values into any form by having Javascript validate the input. So if a user inputs characters where only numbers are allowed, the user will be notified immediately and not allowed to submit the form until it is corrected. And this is done before anything is ever sent from the browser to the server.

But if the user has input all valid values, we still validate all the data at the backend before we store anything in the database. This means verifying that any referenced object ID actually exists and making sure the provided IP address is actually valid (within the 0.0.0.0/0 - 255.255.255.255/32 range). If anything is out of place, a message is sent back to the user about it.

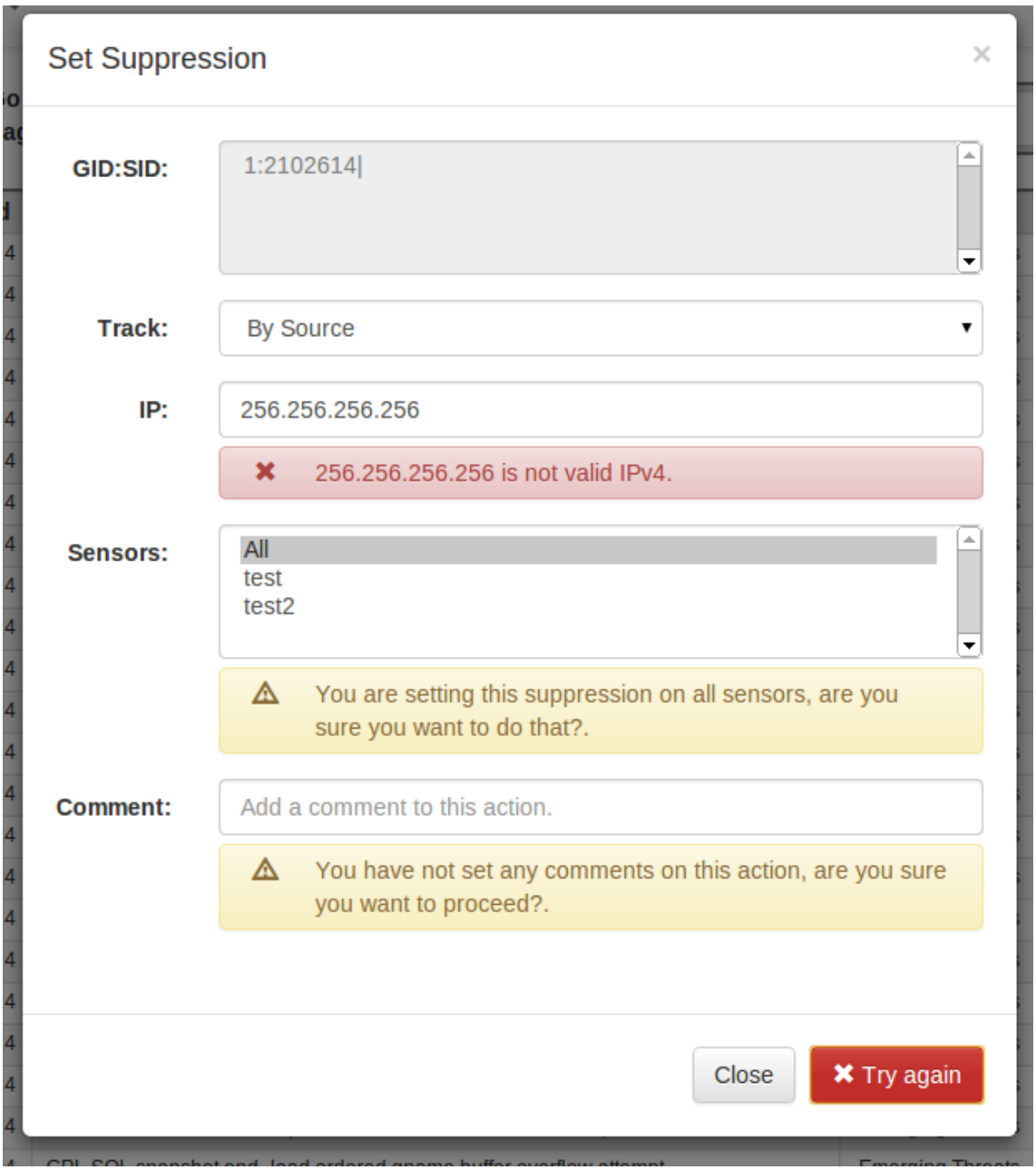


Figure 19: Form validation

6.9 Logging

Complex software needs to log what is happening, to simplify the understanding of what happens when certain things go wrong. It is also needed to document what is done, in case someone would need to make sure that an update ran or other actions have been taken by the system. As Snowman is a fairly large and complex piece of software, we needed to think about logging of the internal workings.

For the logging of internal events in both the Snowman-client, and the Snowman-server, we decided to use the standard Python logging libraries. These libraries allow us to log events of importance inside our code, depending on how important these events are. The logger would then log information about things like; which modules the events occur in, the time an event happened, and a message describing the event. The levels of logging are Debug, Info, Warning, Error and Critical, sorted in an ascending order of importance.

Handlers can be assigned to the logger, which decides where to store the logged events. Snowman uses one handler by default, which writes events to a file. The configuration file for Snowman decides where this file is stored and which severities are stored. Under normal operation, it is recommended not to log Debug messages, as they are generally not needed and therefore only use up disk space and may slow down the overall performance.

The Python logging facilities are configurable and flexible. If future needs would require some events to be stored in a database or send messages to users (via SMS for example), the only thing that would be needed to be done is to add a new handler.

6.10 Configuration Files

Snowman's configuration files exist to give users some flexibility by providing a set of options that specify how Snowman operates. The configuration files originated from a need to store database credentials, which of course would differ from system to system. This was expanded to include some options that users might want to set differently depending on their situation, for example if new rule revisions should automatically be active in the production system or not. Snowman requires a configuration file for the server and one for each client, detailed below. For example configuration files see appendix.

6.10.1 Server Configuration File

The server configuration file contains file paths and other options used for logging and client connections, along with the options described below:

Rule revisions

Users can specify the number of revisions to store. Snowman will automatically delete the oldest revision when the revision count for one rule exceeds this number. The default value is 2, which is just enough to let users roll back to the previous working revision after an update. Users can also specify whether incoming revisions should automatically become active (i.e. go right into production) or remain inactive until manually activated.

Rule sets

There is a possibility that a rule will be moved from one rule set to another by a source, for example the Snort rules contain a "deleted" set, which contains rules that were previously part of other rule sets, but are now considered obsolete. Users can also choose to

re-arrange rules across rule sets, which may create conflict during updates. This means that some users will prefer that rules automatically moves to the rule set dictated by the update, while others would like the rules to remain in their original rule set. This functionality is therefore customizable in the server configuration file.

Rule filters

Another thing that might cause problems is rule filters. Since there can only be one filter of each type per rule, users must decide wheter they want new incoming filters should automatically overwrite old filters or not. In the server configuration file, users can specify that filters should be *a*) always overwritten; *b*) overwritten unless the previous filter was set manually by the user; or *c*) not overwritten at all.

Alert messages

Rule alert messages can appear both inline and in a separate file, and one of these sources must take precedence if they contain different alert messages. This behaviour can be configured to always use the inline or external specification, or which ever is encountered first.

Rule caching

Users can specify whether all rules should be cached in memory during an update, even if they are not changed. It might be useful to enable this if the updates contain a lot of filters, as it will reduce database access when updating the filters.

Update files

Since there is no documented standard for file names and file contents within an update-package, users can specify both a whitelist and a blacklist over which files to parse during an update. If present, the whitelist will take precedence over the blacklist. In the whitelist, users specify a list of filenames together with their expected contents. If a whitelist is specified, Snowman will look for, and parse *only*, the following files:

1. One file containing rule classifications.
2. One file containing generator messages.
3. One file containing alert messages.
4. One file containing rule filters.
5. An arbitrary number of files containing rulestrings.

The whitelist provides the most effective update parsing, as only the files specified are parsed.

If a blacklist is used, Snowman will parse every file in the update except files with extensions specified in the blacklist (e.g. ".c" and ".so" files are skipped). This will slow down the parsing, as Snowman has to check if each line in each parsed file matches a known entity, such as a classification or a rulestring.

6.10.2 Client Configuration File

Every client in the system requires its own configuration file. In this file, the credentials of the sensor on which the client operates are stored, along with database and logging options and paths to required directories and files. Parametres which impacts the synchronization are also included in this file, most notably the request-size, which controls

the maximum amount of rules requested in each request. Depending on the resources available on the server, large requests might take too much time to handle, which can make the connection time out. On the other hand, too small requests would increase the synchronization-time because of I/O-waiting between every request. It is therefore natural to let users define the request size in the configuration file.

6.11 Documentation

How the software is documented.

6.12 Deployment

The deployment of Snowman is a two-stage procedure. First, the central server needs to be installed and configured. After the server has been verified to be working as intended, the Snowman-clients can be installed alongside of Snort on the sensor.

Both the server and the client are delivered packed in Debian-based installation files. These installation files will install the Snowman software, in addition to making sure that the required dependencies are also present on the machine.

However, there is one exception to the dependency solving. The server is delivered in both a Debian-flavour in addition to an Ubuntu-flavour. The reason for this is that some of the Python libraries used are currently not in the debian-stable repository, and for Debian it is required to install them via the Python package source (pip). After the installation, we therefore provide some utilities as a double-check, to be able to verify that all the required tools are present.

As all of the Snowman software is delivered in packages, automation of the installation can be achieved trough the use of standard tools like *aptitude* and configuration tools such as *puppet* and *cfengine*.

6.12.1 Snowman Server

To deploy the Snowman-server, it is wise to do a couple of considerations first. Snowman uses external software for its webserver and database and because Snowman is a quite flexible piece of software, it is possible to change which technology is used with a small configuration change.

The web interface is powered by a Python WSGI [**?**] gateway and is thus very flexible in which server technology is serving it. The only requirement would be that the web server supports WSGI. As default, the provided configurations use Apache 2 as their web server.

For the database, as the Django database ORM is used, several technologies can easily be utilized. Sqlite, MySQL (and thus MariaDB), PostgresSQL and Oracle are all supported. Sqlite might work for smaller installations, where simplicity is preferred over performance. The only requirement for an Sqlite database would be access to write a file in the filesystem. However, if performance is required, a dedicated RDMS (Relational Database Management System) would be more suitable. A bog standard and free alternative here is MySQL.

Installation

When the database technology has been selected and the web server is available, the installation of the Snowman package can be done. The package is delivered in two versions; one for Debian and one for Ubuntu. Both would work on both systems, as the only

difference is the dependency list. In the Debian version, a couple of dependencies are omitted as they are not in a new enough version in the debian-stable repositories. These dependencies need to be installed manually using python pip:

- django (version >= 1.6)
- ??

Configuration

After the installation, a couple of configuration steps remain. First, in the file "/usr/share/snowman/srm/settings.py" the following variables need to be updated:

- SECRET_KEY: Create a random string, and insert here. It is used for signing messages, and make sure no tampering happens in the clients of the web interface.
- ALLOWED_HOSTS: An array of host names used by the server. If the webside is requested with any other host names than those listed here, an error-page will be displayed instead of the web interface.
- DATABASES: A dictionary which contains the database-settings. More information on how to configure these settings is found in the Django documentation.

The rest of Snowman's configuration can be found in "/etc/snowman/snowman.cfg". All the configuration parameters are well documented in the configuration file.

To configure the web server, an Apache 2 configuration file is provided in "/etc/apache2/conf-available/snowman.conf". If this is to be used, a symlink to this file can be created in "/etc/apache2/conf-enabled/", after which Apache 2 needs to be restarted.

When the configuration changes are complete, the command "snowman-initialize" should be used to generate the database-schema and intialize the database with some initial data. The output of this command would also signal if the database settings are correct, as it cannot create the initial data without access to the database.

Verification

When Snowman has been configured, it is time to verify that the configuration is valid. There are five things that need to be verified:

- Database availability.
- Access to logging locations
- Access to scratch-location on the filesystem.
- Availability of the webinterface
- Availability of the socket used by clients to download updates.

The command "snowman-test" is provided in order to have an automated way to test all these parametres. If everything is OK, a message will state so and the program returns 0. If any of the above bullet points fails their corresponding test, a message is displayed, and the test returns 1.

6.12.2 Snowman Client

The deployment of the Snowman-client is a simple three-step approach:

1. Install the snowman-client package
2. Update "/etc/snowman/snowman-client.config" with database-settings, address for the central server, sensor name and sensor password.
3. Add the sensor to the Snowman-server, for example trough the web interface.

To be able to verify that everything is as it should be, a tool is provided to test that the client is properly installed and configured. The command "snowmanclient-test" will verify all these points:

- The required libraries are present.
- The configuration specifies a database that is accessible.
- The location for creating rule-files is writable.
- A contact to the central server can be established.

snowmanclientd

There is a daemon supplied with the Snowman-client, named "snowmanclientd". It is responsible for allowing the central server to make contact with the client. It is set up to automatically start at bootup, but it is also possible to control via the ordinary linux command "service"; "service snowmanclientd start|stop".

7 SOFTWARE TESTING

7.1 Strategy

The overall strategy of the project when it comes to testing has, first and foremost, been to have regular meetings from Avdeling BKI where we conducted demonstrations of the software. This has lead us to either confirm elements as feature complete or to create a list of elements to either fix or improve.

We have also not had any specific regimes when it comes to bug fixing, we have mostly just handled them when they have been discovered them.

We could describe our software testing strategy as ad-hoc based, as it is quite common in agile projects. Our main focus was on the performance testing.

Unit testing has not been used extensively in this project, except to test that data from an update is correctly inserted into the database. Source code listings of all unit tests in this project can be found in Appendix **??**.

7.2 Description of Problems

7.2.1 Rule insertion

Snowman extracts various types of data from the rule string and inserts this into the database in different tables. Since an update can contain thousands of rules it proved to be very difficult to effectively verify that all rules were correctly inserted into the database. To address this, a test suite was set up executing a dummy update with an example rule string containing all possible options.

```
1  def test_updateRule(self):
2    # Insert the rule
3    self.update.updateRule(self.rulestring, "example.rules")
4
5    try:
6      # Verify that all related objects exist
7      rule = Rule.objects.get(SID=1, active=True, priority=10)
8      generator = rule.generator
9      ...
10   except Rule.DoesNotExist:
11     self.fail("Rule does not exist")
12   except Generator.DoesNotExist:
13     self.fail("Generator does not exist")
14   except ...
15
16   self.assertTrue(rule.active==True)
17   self.assertTrue(int(rule.priority)==10)
18   self.assertTrue(generator.GID==1)
```

These tests were also very useful during the refactoring of the Update module.

7.2.2 List Pagination

One problem that has plagued the software throughout the development has been the pagination functionality in the GUI. Due to it using AJAX to fetch other pages in the background, if we changed pages so fast that the system could not catch up, it would just end up never loading anything due to AJAX's asynchronous nature[1]. This has been remedied by using some logic to check for outstanding AJAX calls but a better solution would be to implement some other mechanism or framework for pagination. The remedy has also put some extra latency on the rule list as waiting for the AJAX calls might take some time.

7.2.3 The Ever Changing Number of Changes

One smaller bug that popped up was on the Changes page where the number of new rulesets, rules and rule revisions there has been in the latest updates are displayed. Initially, only the rule revision was tied to the Update object and we then traversed from the revision object to the rule object and counted how many revisions that rule had, in order to determine if the rule was new[2]. But using this method led to an undesired outcome when a "new" rule gets a new revision in a later update. As the count for revisions is done in real time, this rule will suddenly not be listed as new anymore in the old update.

This problem was solved by tying all relevant new objects to the Update object and then just listing those relations. The downside of this is a lot more relations to store in the database, but the Changes view was one of the more important features so it had to be done this way.

[1] The code does not wait for AJAX to finish before moving on.
[2] A new rule will always only have one revision.

8 PERFORMANCE ANALYSIS

8.1 Theoretical Analysis

The purpose of the theoretical performance analysis is to examine the most important features of Snowman and similar software, to form opinions on the expected performance of each software. The theoretical analysis is used to create concrete benchmarking tests presented in section 8.2. The software analysed is BHTB, Snortmanager and two versions of Snowman.

8.1.1 Effectiveness of Update Processing

As described in chapter 6, Snowman extracts several rule options from the rulestring during parsing. These options will either create or update objects connected to the rule, such as rule set, rule message and classtype. These logical relations add to the complexity of the database transactions during the update process, as multiple database tables are involved. BHTB and Snortmanager, on the other hand, write rule data to a single table. It is therefore expected that BHTB and Snortmanager will generally exhibit a more effective update processing.

Incremental updates

One of the expected strengths of Snowman lies in processing incremental updates, i.e. updates containing only a small number of changes. It is significant to gauge performance for incremenal updates, as most real-life updates usually contain between 10 and 100 changes. Ten updates from 20.03.2014 to 17.04.2014 contained on average 36.8 new and 53.9 updated rules[1]. Snowman will effectively handle these updates, as it stores the checksum of the files in the update. Storing the checksum for every individual file[2] is unique for Snowman. It allows Snowman to completely ignore files without changes, which means that only the files with rule changes are parsed. This is particularly useful as the current official Snort rules contain over 100 files[3]. It is therefore expected that Snowman will effectively process updates that contain relatively few changes.

8.1.2 Effectiveness of Rule Distribution

The rule distribution, or synchronization, is a feature of Snowman and BHTB where rules are distributed from the server to the sensors. Since Snowman and BHTB use different strategies for distribution, Snowman uses a local client database as described in chapter 5.1.1 while BHTB pushes all files out to the sensor at each synchronization, it is previsioned that Snowman will perform better because of the fact that only transfers over new changes rather than everything, every time. Also, since BHTB distributes everything, every time, it is expected to have a flat performance curve, since the timing will be dependent on the bandwidth rather than processing power.

Snowman's server-client connection is more complex than the one of BHTB expect a longer processing time for setting up the connection.

[1] Source: http://www.snort.org/vrt/advisories
[2] Checksum is stored only for files that are parsed.
[3] As of May 2014

BHTB operates with a more crude way of distributing rules to sensors.
Snowman will only synchronize changes

8.1.3 GUI Latency

A major complaint from Avdeling BKI was that they experienced a large latency in BHTB's web component, that they had to wait long periods for it to load data. We've attempted to remedy this problem in Snowman by not loading absolutely everything into the GUI every time, like BHTB does. It is expected that this will reduce the latency in the GUI, as we would be processing and displaying only 100/28000 rules as opposed to all 28000 rules.

8.1.4 Linearity in Performance

We're expecting all of the software to have a linear performance curve, or better (downwards tendency), as an upwards pointing performance curve is a sure sign that something has been programmed very wrong. If performing one task takes 1 second, performing 10 tasks should take 10 seconds or less.

8.2 Practical analysis

Since Snowman is similar to BHTB and Snortmanager, it has been important to benchmark their performance in various formal test cases in order to highlight the strength and weaknesses in each software solution. The purpose of the tests is to reach final conclusions on key questions regarding the performance of Snowman, and to point out where the difference between the three software packages lies.

To get a picture of how the software performs on different systems, it was tested on three architectures (table 5). To minimize error, each test was run five times where the mean value of the runs is considered the valid test result. All tests can be reproduced with the test procedure documentation in appendix.

8.2.1 Definitions

The testing is split up into *test suites*, which contain a *problem* in the form of a question. The problem forms a clear description of what is to be tested, and how results should be evaluated. A test suite also contains one or more *test cases* which exist to address the problem. Test cases represent individual tests, and describe the input data and constraints. Test cases are carried out on the different systems, and results from each test case are reffered to as the *test results*.

8.2.2 Environment

All tests are carried out on three systems, named *S1*, *S2* and *S3* (table 5). These systems differ in processing power, available memory and storage technology, and the results will indicate what impact these factors have for software performance. The performance testing in this report is also prone to error, as tests might get disturbed by other background processes etc. Testing on three systems gives results with a higher confidence, as results are checked aginst each other for inconsistencies. When an inconsistency in results is found, the test is run again to see if the inconsistency prevails.

8.2.3 Test suites

Even though Snowman, BHTB and Snortmanager share the same goal of being a rule management system, it is not immediately obvious how they can be tested against each

System	Processor type	Memory	Storage
S1	Intel® Core™ 2 Solo, 1.4GHz	4GB RAM	5K RPM HDD
S2	Intel® Core™ i7, 6x3.2GHz	12GB RAM	10K RPM HDD
S3	Intel® Core™ i5, 4x3.2GHz	16GB RAM	SSD

Note: See appendix for full details.

Table 5: Test systems.

other to compare their performance. The first step in the performance testing has been to identify the areas where the three software packages share, to a certain extent[4], the same functionality. In the test planning, considerations have been made to ensure that the tests hold an acceptable degree of fairness (i.e. tests are designed so that none of the software enjoys any improper advantages or disatvantages), and that the tests are pertinent to the daily operation of the software and the Snowman requirement specification.

Snowman, BHTB and Snortmanager all have the functionality to download and process an update from an external source. The first group of test suites presents different test cases to benchmark how each software performs in update processing.

8.2.4 Update processing tests

The purpose of the tests in this section is first and foremost to test how quickly the software can process an update, and if the processing time is linear to the update size. It is interesting to test for linearity as this may help point out programming errors. To get a complete picture of the performance, the tests are set up with different constraints such as update size, number of files and number of changes from one update to the next.

Tests numbered 1-1 through 1-4 use an artificially generated update package where all rules contain the same data[5].

Test 1-1

Problem: How fast can the software process an update?

The purpose of this question is to determine the average processing time per rule. Results are ranked from short to long processing time, where shorter is better.

Test cases:

To address this problem, five test cases were introduced. The tests contained an artificially generated update with 1, 10, 100, 1000 and 10000 rules, respectively. Rules were split into files with ten each. Each test case represents one update, and the names denote the number of rules in the following structure: *SYN-number of rules*. The test is also carried out with a realistic update package, *SF-28064*.

[4] Snowman, BHTB and Snortmanager have been built to tackle many of the same challenges, however, the actual implementations may differ severly. For an extended walk-through of differences in implementation, refer to chapter 2, and chapter 10.

[5] Only signature IDs are different. The rules contain a message and a classtype, see appendix for full description.

Test case	In test	Description
SYN-1	Test 1-1, 1-2	Blank database.
SYN-10		
SYN-100		
SYN-1000		
SYN-10000		
SYN-1000-B	Test 1-3	All rules in one file.
SYN-1000-C	Test 1-4	Pre-populated database. No changes in update.
SYN-1000-D	Test 1-5	Pre-populated database. Revision change for all rules
SF-28064	Test 1-1	Blank database.
SF-28064-B	Test 1-6	Pre-populated database. Update has one rule change.

Note: Rules are split into files with ten rules per file unless other is specified.

Table 6: Test cases in update processing.

Test 1-2

Problem: How strong is the linear correlation between processing time and the size of an update?

This question rises from the requirements specification of Snowman (chapter 3), where it is stated that Snowman shall exhibit a linear increase in processing time in correlation to the number of rules in the update (where the number of rules depicts the update size). Results are ranked from strong correlation to no correlation, where stronger is better.

Test cases:

This test uses the same test cases as Test 1-1.

Test 1-3

Problem: Does raising the ratio between files and rules increase processing time?

Updates can come with the rules either gathered in one file, or distributed over several files. This question is asked to examine the difference in processing time for these two scenarios. Results are ranked from no difference to big difference, where less difference is better.

Test cases:

This test compares the *SYN-1000* test case from Test 1 with a test case with the same number of rules in *one* file (*SYN-1000-B*).

Test 1-4

Problem: Is the processing time shorter when the update contains no new rules?

This is a test for update processing when the update is not new (i.e. it has been completely processed by the system before). To minimize system load, it is essential that already processed updates are (in practice, they should be neglected) by the system. Results are ranked from shortest to longest processing time, where shorter is better.

Test cases:

This is a compound test where a test case is run two times in succession. The *SYN-1000* test case from Test 1 is run first to populate the database, before it is run again (*SYN-1000-C*).

Test 1-5

Problem: Are the processing times for two updates identical when only revision numbers are changed between the updates?

This question measures how one small change in all rules affects procesing time. This test runs the *SYN-1000* update to populate the database, and then the *SYN-1000-D*, which contains a revision number change for all rules. Processing time is expected to be faster for the second update, since the database will already be populated with the majority of the data. Results from this test will be ranked by the difference in processing time between the first and the second updates, where bigger difference is better.

Test 1-6

Problem: Are the processing times for two updates identical when only one rule has changed between the updates?

This question seeks to determine how the software handles an update when there is only one change from the previous update. This is an important factor to consider, since an update usually contains only a small amount of changes from previous updates. Results are ranked from short processing time for second update to no difference in processing time, where shorter time is better.

Test cases:

This test suite contains two test cases with an update from a real source. The *SF28061* is run first to populate the database before *SF28061-B* is run, which contains one change (one of the rules has an updated revision number).

8.2.5 Rule distribution tests

8.2.6 Interface loading tests

These tests will evaluate the speed of the user interface. Listing rules and rule sets. Uses timer in Google Chrome. Both tests use the SYN-10000 package. The reason for using this is..

Test 3-1

Problem: How quickly does the user interface list rules?

Test cases:

This test uses one test case, called *list rules*, where 100 rules are listed in the user interface.

Test 3-2

Problem: How quickly does the user interface list rule sets?

Test cases:

This test uses one test case, called *list rule sets*, where all rule sets are listed in the user interface.

8.2.7 Abandoned tests

Not conducted due to time limitations. real-world tests. Would have been interesting to run distribution test to multiple sensors to verify parallellization. Tests with more realistic

rules. Testing of CPU usage.

9 RESULTS OF PERFORMANCE TESTING

This chapter presents the results from the performance testing. Results are mean times calculated from five sequential test results, in microseconds. Test cases and systems are listed in rows, with one column per software. See appendix for a complete listing of results. Results for interface performance, update and synchronize are presented in Tables 7, 8 and 9, respectively.

Test case	System	Snowman v 0.5	BHTB
List rules	S1	2508	924.561
	S3	1045.950	657.408
List rule sets	S1	11306	39432
	S3	4676	10524

Table 7: Test results for interface performance.

Test case	System	Snowman v 0.4	Snowman v 0.5	Snortmanager	BHTB
SYN-1	S1	1058.179	1415.484	228.617	125.236
	S2	622.640	804.681	93.403	65.281
	S3	151.946	196.160	36.960	18.175
SYN-10	S1	2289.518	1427.712	265.275	148.323
	S2	1668.142	808.218	107.554	72.025
	S3	327.655	195.159	37.569	19.711
SYN-100	S1	17519.385	1568.224	1251.275	185.970
	S2	12197.192	865.496	139.005	84.913
	S3	2356.610	343.033	159.113	25.024
SYN-1000	S1	167645.267	2568.235	9470.460	568.333
	S2	114617.561	1098.159	460.394	158.351
	S3	22830.358	1823.785	1360.276	60.313
SYN-10000	S1	1795175.128	14179.095	92428.555	3606.043
	S2	1162468.835	5761.811	5105.158	910.172
	S3	228038.066	16804.950	13523.887	440.334
SYN-1000-B	S1	147170.285	2508.530	1836.396	445.476
	S2	113901.478	1245.906	496.204	157.817
	S3	20367.838	404.022	228.044	49.908
SYN-1000-C	S1	296.272	309.576	1763.480	7.816
	S2	186.215	169.476	829.230	4.543
	S3	56.152	54.824	205.956	1.310
SYN-1000-D	S1	1371.722	1431.436	64100.000	563.682
	S2	9682.763	748.258	31999.710	85.289
	S3	16998.276	2022.763	10716.689	83.275
SF-28064	S1	9175886.000	63961.545	43391.700	5638.424
	S2	3817584.070	26875.246	21127.828	1715.521
	S3	1267483.848	12522.786	8039.046	1017.561
SF-28064-B	S1	28200.953	9239.670	239878.897	5606.518
	S2	22673.225	5489.009	80009.077	2396.780
	S3	5260.553	1707.588	63626.550	1004.424

Table 8: Test results for update processing.

Test case	System	Snowman v 0.5	BHTB
SYN-1	S1	1645.639	1501.465
	S2	1503.815	1467.612
	S3	371.537	3.300
SYN-10	S1	1828.779	1489.364
	S2	1752.954	1472.808
	S3	453.362	3.462
SYN-100	S1	3975.408	1489.645
	S2	4036.130	1473.355
	S3	1094.713	4.492
SYN-1000	S1	24921.176	1771.004
	S2	25374.218	1503.511
	S3	7759.566	15.132
SYN-10000	S1	239641.965	1839.841
	S2	251607.202	1593.889
	S3	16862.160	121.677
SYN-1000-B	S1	24916.964	1522.719
	S2	25228.116	1481.411
	S3	7252.062	4.156
SYN-1000-C	S1	4265.931	1775.423
	S2	4297.144	N/A
	S3	2278.760	1097.711
SYN-1000-D	S1	6523.340	1775.664
	S2	6544.584	1513.944
	S3	11642.046	1064.944
SF-28064	S1	112509.497	1758.258
	S2	105555.617	1584.972
	S3	40004.218	1062.806
SF-28064-B	S1	26362.894	1754.601
	S2	23033.204	1584.696
	S3	8839.964	1117.693

Table 9: Test results for sensor synchronization.

10 ANALYSIS OF PERFORMANCE TESTING RESULTS

10.1 Effectiveness of update processing

This section discusses the most important results from the update processing tests. Table 10 displays the average processing time per rule calculated from the synthetic update containing 10000 rules and the realistic update containing 28064 rules. As can be seen, BHTB is significantly faster than the two other across all systems. It came as a big surprise that BHTB performed so well in the update tests, as our client had listed poor update performance as one of its major defects. The results are probably best explained by the very simple nature of BHTB's data structure. Also note that these tests might not reflect the reality that our client faces, as they are run in a minimalistic environment without any sensors or other database-objects that might affect BHTB's performance in a real environment. Snortmanager also performed well in the tests, which is expected as it has a very similar data structure to BHTB in that it is very simple.

Test	System	Snowman 05	Snortmanager	BHTB
SYN-10000	S1	1.4179	9.2429	0.3606
	S2	0.5762	0.5105	0.0919
	S3	1.6805	1.3524	0.0440
SF-28064	S1	6.3962	4.3392	0.5638
	S2	2.6875	2.1128	0.1716
	S3	1.2523	0.8039	0.1018

Note: All times in milliseconds.

Table 10: Average processing time per rule.

Snortmanager starts to struggle when more files are introduced into the tests. As can be seen in table 11, there is a big difference between tests *SYN-1000* and *SYN-1000-B*, where we have the same number of rules, but spread over more files. This problem does not seem to exist in either Snowman nor BHTB.

None the less, both Snortmanager and BHTB pummelled Snowman v0.4 into the ground in these tests, which led us to completely rework our update program workflow. Our problem was that for every rule, we were writing its data to the database and then moving on to the next rule. This caused a lot of busy-waiting for the database. You can see that the times accelerated a lot on the machine with the lower end harddrives, so the problem also manifests itself more when the harddrives can't keep up.

We proceeded to rewrite the code so that all the rules are parsed into memory first and then is committed into the database in one big query. As you can see in table **??** we improved Snowman's performance in v0.5 with as much as xx% in some tests.

While we still didn't fulfil the performance goal, considering the difference in complexity and structure, we feel the difference is acceptable. The results in this test is a very

Test	System	Snowman 05	Snortmanager	BHTB
SYN-1000	S1	2568.235	**9470.460**	568.333
SYN-1000-B	S1	2508.530	1836.396	445.476
SYN-1000	S2	1098.159	460.394	158.351
SYN-1000-B	S2	1245.906	496.204	157.817
SYN-1000	S3	**1823.785**	**1360.276**	60.313
SYN-1000-B	S3	404.022	228.044	49.908

Note: All times in milliseconds.

Table 11: Comparison of processing time for many files vs one file.

good indicator that performance testing during development is a very useful thing to a development project.

10.2 Effectiveness of rule distribution

As we expected, BHTB had a very flat performance curve in this test, but not exactly flat. There is a small increase in time spent when the number of rules go up, as you can see in table **??**, meaning there is some degree of processing time infuencing the results.

Still, considering the tests on S1 and S2 were carried out on the same network and sensor, and S3 were carried out on a completely different network and sensor, it is apparent that distribution from BHTB is mostly determined by how fast the data can be moved from the server to the sensor.

The same difference in testing environments is apparent in the Snowman tests. S1 and S2 have pretty much the same results while S3 probably benefits from it's different hardware and network setup. This leads us to conclude that the performance of distribution is dictated by the bandwidth and by the hardware of the sensor, and not so much the hardware of the central server.

However, there does not seem to be a pure performance gain over BHTB as we expected by going for a distributed model with a change based distribution protocol. But we are seeing a significant reduction in time spent distributing when there are only updates and not a massive batch of rules. While BHTB uses roughly the same time on tests SF-28064-A and SF-28064-B, we use about 80% less time on test B than on test A.

This gives merit to the model we picked for our distribution architecture and with a little more performance optimizations, the overall times might improve further as well.

10.3 GUI latency

These tests probably entails the most grim part of our performance results as we seeminly have failed to produce an improvement over BHTB when it comes to displaying rules, something that does not make much sense if you do the math. We are only fetching and displaying a fraction of the number of rules that BHTB does[1], yet we spend about twice as long on it.

We have not spent much time investigating the cause of this, but we strongly suspect its a combination of our more complex data structure, coupled with our rather novice

[1] About 100 to 28000.

use of a complex template framework such as Django.

A small optimization was attempted by enabling a setting that lets Django prefetch related objects from the database and that did improve the results somewhat, but not enough to be noticable.

10.4 Linearity in performance

Our tests show that all the systems were more or less exactly linear, which means that none of the systems are suffering from bad programming that manifests itself exponentially.

Table 12 shows the linear correlation between the test results for the synthetic updates with 1, 10, 100, 1000, and 10000 rules. The first dataset is the test results and the second dataset is $\{1, 10, 100, 1000, 10000\}$. As can be seen, the performance is close to linear for all software across all systems.

System	Snowman 05	Snortmanager	BHTB
S1	0.999945	0.999999	0.999695
S2	0.993996	0.999627	0.999931
S3	0.999999	0.999999	0.999983

Note: All times in milliseconds.

Table 12: Empirical linear correlation coefficients for update processing.

10.5 Conclusions

Snowman did not outperform either BHTB or Snortmanager in any of the tests, but through the test we managed to discover a big performance bottleneck in Snowman's Update module that we managed to fix in time. The fix resulted in a big improvement in performance.

The extra latency in Snowman is likely due to it's more complex data structure surrounding rules, which means more processing and data movement is needed for many operations. The project has also not been able to exploit all possible optimization possibilities and techniques, due to limited time.

These tests stand to point out that performance testing in software projects can reveal performance problems early enough in the development to do something about it.

11 CONCLUSIONS

11.1 Results

This project set out to develop, from the ground up, something that were to be better than a prototype already in use. And we have produced some that does indeed works and, in many cases, better than it's predecessor. We did not manage to build in all the features we outlined in our goals, but the features missing are also features not present in the predecessor BHTB.

We discovered through our performance tests that we did not reach our goals when it came to making Snowman more effective than BHTB, but this can be acredited to the more complex data structure which results in more data needing to be processed and moved to/from I/O devices.

Our performance tests in chapters 8 to 10 also revealed that actually conducting them in a software development project is a very good idea, as we discovered a big bottleneck in our Update module and managed to fix that and improve our performance significantly. Some aspects of Snowman are still not within acceptable performance times, but the optimization done on the Update module brought it into an acceptable range.

While we have not conducted tests on the matter, we believe Snowman does not have the same scalability problems that BHTB seems to have when adding more sensors to the system. This has to do with our distributed model, removing the bottleneck of being dependant on a central system for the distribution of rules and removing the bandwidth strain of distributing everything, every time.

We also created a GUI that does the same and more than what the GUI of BHTB does. It is not perfect by any stretch of the imagination, but it features more essential features such as form validation and user feedback.

The project also reveals that using frameworks such as Django to create an object abstraction on top of the database can really let you create a lot of functionality in a shorter amount of time, than if you had to work directly on the database.

And last but not least, the members of the project group has learned a great deal when it comes to software development projects, especially when it comes to working with bigger enterprise oriented frameworks such as Django, when it comes to time management and about IDS systems in general.

11.2 Future Development

At the start of the project we were ambitious with our project goals and the client had a long list of functionality they wanted implemented. While a large chunk of the functionality made it to our latest version, we had to sacrifice some due to time constraints.

Which were the functions we put in the "if time permitting" pile from the start, the ability to comment rules, the ability to write new custom rules and to have some sort of way to check for errors in the rules before they are distributed. There is, however, no problems adding these features in future work, as we've strived to make the program modularized.

To solve the functionality of checking for errors in rules, we discussed early on if something like Dumbpig[38] could be used. It gives feedback on rule syntax as well, so it could also be used to check rules that have been written by the user for mistakes or errors.

There are also more optimization work that could be done to speed things up, especially when it comes to fetching lists of rules. Rule distribution will also benefit from a similar optimization as done with rule updating.

The GUI could probably also benefit from more work, as it has a few quirks and odd bugs. It would probably be beneficial to find some other way of doing pagination, as the implementation in the current iteration is not optimal. There's also some cosmetic improvements to be done to tighten up the looks, there are a few places where theres too much clutter once you've navigated and opened too many things.

We also compiled an improvements list from our client on a few matters, which is available in appendix **??**.

11.3 Group Evaluation

11.3.1 Introduction

At the beginning of this project we all agreed on that we wanted to reach for that often unreachable top grade on this project. To accomplish this, we've worked countless hours to the best of our abilites and we've had virtually no issues or problems to sidetrack us as a group, so we've been able to fully focus on the task at hand.

The group has worked well as both a team and as individuals, drawing from each others strengths and expertise. We've created something that could very well either live on in service of the information security community or inspire others to further improve or recreate.

The work that has been done over the past few months is something the group can be proud of.

11.3.2 Organization

While we had a designated group leader, we never really got in a situation where we needed one. Most of our decisions or problems were solved as a group through discussion and a democratic approach and that worked well for our group.

It seems like we hit the nail pretty much dead on when it came to our project plan, which we have more or less followed throughout the entire project. The development cycle lengths and intermittant meetings has allowed us to be very flexible and agile in our development, as well as being more or less on schedule.

Spending some time planning everything before we started programming gave us a good head start and even saved us some time writing this report as we had a lot of its components already made. When we completed the initial planning phase, we held a "project decision meeting" with Avdeling BKI where we introduced the system models we had made so that Avdeling BKI could decide what they wanted or not. We felt this was a good idea, as we could then get some valuable feedback before we started programming.

Our approach to the development cycles was mostly as described in section 1.7.1, we conducted syncronizational meetings once or twice a week to chart out the course and keep up to date with what the others were doing. But for the most part, because we had devided the software into modules, we worked individually. We feet this was the way

to go, since we could all work comfortably at home in front of our favourite computer, being more productive that way.

When it came to the thesis, we set a good month and a half of our project time for it and we think it paid off, especially as we expanded it to include the performance testing part. We also devided the writing part into three draft cycles, so we could get valuable feedback from our mentor and client.

11.3.3 Work distribution

For the most part our work distribution has been a “free for all”, meaning the group members picked freely from what they wanted to work on during the development cycle, within the objectives we set for that cycle. This worked out fine for the most part, but we feel we probably could have been slightly more aggressive with how many features we finished within the cycles. This left with with a bigger workload towards the end of the development as opposed to the beginning.

11.3.4 What could have been done differently

As most bachelor thesis' write towards the end, “if only there was more time”. In hindsight, we probably could've conducted our performance testing earlier in the project, so that we could have more time to implement optimizations. We should've also had a more strict approach to what we were supposed to work on for the different development cycles, planning that out earlier as well.

11.3.5 Subjective views

Thomas Nyheim

For me, this project has had a fair bit of personal interest in its success as I am the one that is going to be using this while working for Avdeling BKI. That meant that the better this project turned out, the better for me it would be afterwards.

I feel we have created something that works well enough that it can be taken further and improved upon still. We've also conducted a small scientific test case which has been a learning experience, as it is not something often done at Bachelor levels at Gjøvik University College. There has also been a learning curve when it comes to Python and Django, which I can take with me in the future and apply to other endevours.

Eigil Obrestad

Skriv om folelser og slikt

Eirik Skogstad

Skriv om folelser og slikt

11.4 Conclusion

The project group has produced a piece of software that works as intended and solves the majority of the features requested of it. The group hopes that it can be made useful in the battle to keep the internet safer, but only time will tell if it will be adopted.

The group has also found that it is quite difficult to achieve performance in software when the expectations of functionality is high. We've also learned the importance of conducting software performance testing before it is released, rather than after. Because we conducted a performance test on our software, we were able to implement optimizations that drastically improved the performance of one of our system modules.

Bibliography

[1] St.Laurent, A. M. 2008. *Understanding Open Source and Free Software Licensing*. O'Reilly Media.

[2] May 2014. Agile software development process. `http://www.rapidsoftsystems.com/agile-development-process.html`.

[3] Roesch, M. 1999. Snort - lightweight intrusion detection for networks. *Proceedings of LISA '99: 13th Systems Administration Conference*.

[4] May 2014. Snort community page. `http://www.snort.org/community`.

[5] Henriksen, D. O. Managing signatures for ids in a distributed environment - a study of a signature management system. Master's thesis, Gjøvik University College, 2012.

[6] Vaskinn, C. & Wikestad, K. Snortmanager. Bachelor's thesis, Gjøvik University College, 2012.

[7] May 2014. Snort additional downloads page. `http://www.snort.org/snort-downloads/additional-downloads`.

[8] May 2014. Pulled_pork. `https://code.google.com/p/pulledpork/`.

[9] May 2014. Oinkmaster. `http://oinkmaster.sourceforge.net/`.

[10] Graettinger, C. P., Garcia-Miller, S., Siviy, J., Syckle, P. J. V., & Schenk, R. J. 2002. Using the technology readiness levels scale to support technology management in the dod's atd/sto environments (a findings and recommendations report conducted for army cecom). *CMU/SEI-2002-SR-027*.

[11] May 2014. Snorby. `http://snorby.org`.

[12] May 2014. Surikata. `http://suricata-ids.org`.

[13] Cohen, D., Lindvall, M., & Costa, P. 2003. Agile software development. *DACS SOAR Report*.

[14] Wikipedia. May 2014. Waterfall development method. `http://en.wikipedia.org/wiki/Waterfall_model`.

[15] Wikipedia. May 2014. Scrum development method. `http://en.wikipedia.org/wiki/Scrum_(software_development)`.

[16] May 2014. Tornado. `http://www.tornadoweb.org/`.

[17] May 2014. Sqlite homepage. `http://www.sqlite.org/`.

[18] Roesch, M. et al. 2012. *Snort Users Manual 2.9.3*. The Snort Project.

[19] Woodside, M., Franks, G., & Petriu, D. C. 2007. The future of software performance engineering. *IEEE Future of Software Engineering '07*.

[20] Vokolos, F. I. & Weyuker, E. J. 1998. Performance testing of software systems. *WOSP '98: Proceedings of the 1st international workshop on Software and performance*.

[21] Denaro, G., Polini, A., & Emmerich, W. 2004. Early performance testing of distributed software applications. *WOSP '04: Proceedings of the 4th international workshop on Software and performance*.

[22] Myers, D. On the use of nand flash memory in high-performance relational databases. Master's thesis, Massachusetts Institute of Technology, 2008.

[23] Eeles, P. November 2005. Capturing architectural requirements. `http://www.ibm.com/developerworks/rational/library/4706.html#N10073`.

[24] Saltzer, J. H. & Schroeder, M. D. 1975. The protection of information in computer systems. *Communications of the ACM 17, 7*.

[25] February 2014. Gnu general public lisence v3. `http://www.gnu.org/licenses/gpl.html`.

[26] May 2014. What is object/relational mapping? `http://hibernate.org/orm/what-is-an-orm/`.

[27] May 2014. Python v2.7.6 documentation. `http://docs.python.org/2`.

[28] May 2014. Should i use python 2 or python 3 for my development activity? `http://wiki.python.org/moin/Python2orPython3`.

[29] May 2014. Python 2.x vs 3.x use. `http://wiki.python.org/moin/2.x-vs-3.x-survey`.

[30] May 2014. Django documentation. `http://media.readthedocs.org/pdf/django/1.6.x/django.pdf`.

[31] May 2014. Pep 257: Docstring conventions. `http://legacy.python.org/dev/peps/pep-0257`.

[32] May 2014. The eclipse project. `http://www.eclipse.org`.

[33] May 2014. Latex project. `http://www.latex-project.org`.

[34] April 2014. Django v1.6. `http://www.djangoproject.com/`.

[35] April 2014. jquery. `http://jquery.com/`.

[36] April 2014. Bootstrap. `http://getbootstrap.com/`.

[37] Leff, A. & T.Rayfield, J. 2001. Web-application development using the model/view/controller design pattern. *IEEE Enterprise Distributed Object Computing Conference*.

[38] May 2014. Dumbpig homepage. `http://leonward.wordpress.com/dumbpig`.

Appendices

A PROJECT PLAN

B MEETING RECORDS

B.1 Project Decision Meeting Presentation

B.2 Meeting Minutes

B.3 Sprint Planning Meetings

C WORKLOG

Our worklog ended up being pretty long and detailed, so we counted it all up and present the numbers in a table instead.

	Nyheim	Obrestad	Skogheim
Prep, planning & meetings	0	0	0
Coding	0	0	0
Thesis	0	0	0
Total	0	0	0

Table 13: Worklog